

Fortinet NSE1 Notes

Module 1: Introduction

Categories of Cybersecurity:

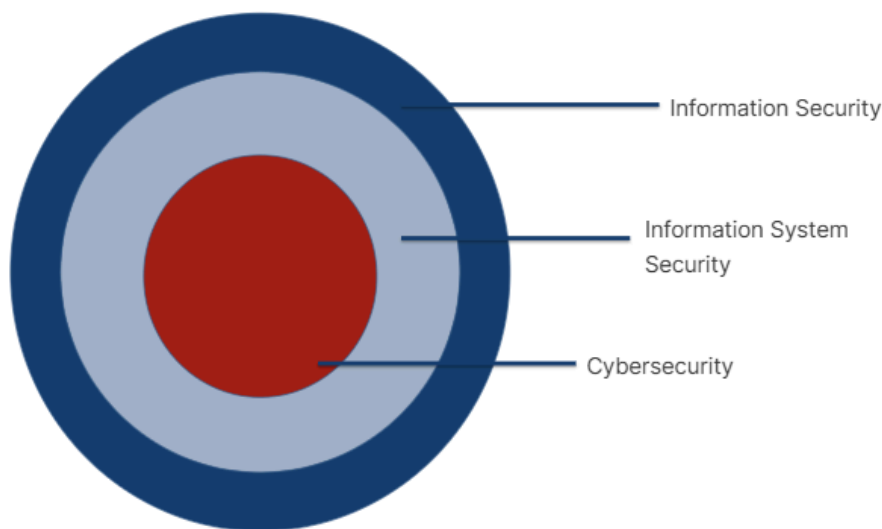
- Critical Infrastructure
- Application Security
- Network Security
- Cloud Security
- Internet of Things (IoT) Security
- People & Processes

InfoSec (Information security): practice of protecting information, includes the tools for preventing, detecting, and remediating attacks and threats to sensitive information

Unprotected information: no protection or controls are necessary

Protected information: some level of protection and control is required, could be labelled confidential, secret, or top secret, depending on protected information's criticality

Information systems security: part of infosec, protection of information systems against unauthorized access, modification, destruction, or denial of access to authorized users



C: confidentiality, data is kept confidential and private

I: integrity, data is authentic, accurate, reliable, and free from tampering

A: availability, data is available to those who need it

Both are opposites of each other

D: disclosure, confidential data is exposed to unauthorized parties

A: alteration, the tampering of data cannot be prevented, or the authenticity of data cannot be determined

D: denial, unauthorized agents are prevented from accessing data

AAA (Authentication, Authorization, Accounting): a security framework that controls resources, enforces policies, and audits usage

Authentication: process of identifying and verifying a person or thing

Authorization: process of controlling access to resources

Accounting: record keeping and tracing of agent activities on computer devices and networks

Module 2: The Threat Landscape

Threat Landscape: the collection of threats in a given context or domain and includes information about the perpetrators of the threats: the bad actors, includes all known and possible threats to computer networks

Bad Actor: persons who try to steal, sabotage, or stop you from using computer systems or accessing information that you are authorized to use and that is stored on or in transit between computing devices, can be grouped based on their character, motivations, and attack methods

Types of Bad Actors:

- Explorer: notoriety is the biggest motivator, curious about the kinds of weaknesses that exist on computer networks and strives to find and exploit them, do not intend to inflict serious damage, commonly use phishing and its different variants
- Hacktivist: idealism drives them to act collectively in common cause against an enemy, collectively crusade against a specific corporation, or go after a political or social organizations that they feel did something bad, their extremism demands anonymity, commonly use botnets and malware, i.e., DDoS attacks

- Cyberterrorist: driven by ideology, their violence is directed more broadly against a society, strive to intimidate and destabilize a society by destroying or disrupting computer or communication networks, like to target online infrastructure, such as nuclear power plants, natural gas pipelines, and electrical power grids, commonly use spear phishing
- Cybercriminal: driven by money, achieve this goal by a combination of phishing, theft of identities or credit cards which they use or sell on the black market, or ransomware
- Cyberwarrior: least self-interested, most dangerous as they have the resources of a nation-state at their disposal, motivated by the national interests of their home country, commonly leverage unpatched vulnerabilities in common operating systems and applications, i.e., zero-day exploits (when the exploit is launched, the vendor has zero days to fix the problem)

Categories of Hackers:

- White Hat: ethical hacker, probes a network to identify vulnerabilities with proper authorization
- Black Hat: malicious hacker who attacks a network for profit or to cause harm
- Grey Hat: hacker who attacks a network, contradicting lawful and ethical behavior, but does not have the same malicious intent as a black hat hacker
- Blue Hat: outside computer security consulting firms that are employed for penetration testing of a system prior to its launch and with the intent to detect and close vulnerabilities

Cybersecurity threat: an action exploiting a vulnerability that results in harm to a network or computer system

Attack vector: a method used by a bad actor to illegally access or inhibit a network, system, or facility

Attack path: the chain of events that occurs when attack vectors are exploited

Main Cybersecurity Threat Categories:

- Social engineering: act of using psychological manipulation to trick people into taking some action that is contrary to their best interests, such as disclosing confidential information

- Malware: software that is designed to disrupt, damage, or gain unauthorised access to a computer system
- Unauthorized access: physically, a bad actor following an authorized person through a door after they have swiped their badge, digitally, a bad actor looking over someone's shoulder as they type their credentials
- System design failure: a security flaw in a computer system or application that the bad actor exploits to gain access to a computer system

Birthday attack: exploits a weakness that exists in some hashing algorithms, the weakness is that multiple input values produce the same output value

Threat intelligence: evidence-based knowledge, including context, mechanisms, indicators, implications, and actionable advice, about an existing or emerging menace or hazard to assets that can be used to inform decisions regarding the subject's response to that menace or hazard, information that is relevant (does the information impact your organization?), actionable (is there enough information to act upon?), and contextual (is there enough information to assess the threat?), must be relevant to your organization

Where is threat intelligence found?

- Internally: found within your organization's IT team in the form of server logs and other data recordings
- Externally: a variety of sources offer guidance and protective measures, often making them accessible for free ([dhs.gov](https://www.dhs.gov), [fbi.gov](https://www.fbi.gov), [nist.gov](https://www.nist.gov))
- Privately: many organizations that specialize in information security provide services for a fee
- Common Vulnerability Scoring System (CVSS): an example of OSINT, a free and open industry standard for assessing computer system vulnerabilities, factors include how exploitable the vulnerability is, how the vulnerability impacts systems, and how effective the new exploits are versus mitigation efforts as the campaign progresses
- MITRE ATT&CK: knowledge base for adversary tactics and techniques
- Verticals: organizations that share threat intelligence information with one another

Processing Threat Intelligence

1. Identify the most vital cyberthreats to stop
2. Assemble threat information from internal and external sources
3. Process the information
4. Analyze the information and look for indicators of compromise (IoC)

5. Disseminate analysis and any new information (using STIX, TAXII)
6. Implement lessons learned

Advanced persistent threat (APT): attacks which can involve extended periods of surveillance, and planning before methodically attacking a targeted computer network

Cyber Kill Chain: a seven step model that describes the stages of a cyberattack

1. Reconnaissance: attacker gathers information about the target and its vulnerabilities
2. Weaponization: attacker creates a payload (malicious code, originally referred to the load carried by a truck, airplane, or missile) or exploit that can be delivered to the target
3. Delivery: attacker delivers payload to the target
4. Exploitation: attacker uses the payload to gain access to the target's systems or data to leverage vulnerabilities
5. Installation: attacker establishes a foothold within the target's systems, installs a rootkit (a software used by bad actors to gain control over a targeted computer or network) or other malicious software that allows the attacker to maintain access to the target's systems even if the initial payload is detected and removed
6. Command and control: attacker establishes a means of communication with the compromised systems
7. Exfiltration: attacker extracts the data and other assets that were the goal of the attack

Assumes that the origin of attack is external to the network.



Kill chain methodology aims to support traditional defense methods.

MITRE ATT&CK (adversarial tactics, techniques, and common knowledge): a guideline that classifies and describes cyberattacks and intrusions, helps understand the attacker's methodology, provides a common language and framework for discussing and analyzing cyber threats, provides a comprehensive overview of tactics, techniques, and procedures (TTPs) used by attackers

Reconnaissance 10 techniques	Resource Development 7 techniques	Initial Access 9 techniques	Execution 13 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 42 techniques	Credential Access 17 techniques	Categories
Active Scanning (1)	Acquire Infrastructure (2)	Drive-by Compromise	Command and Scripting Interpreter (8)	Account Manipulation (1)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Adversary in-the-Middle (3)	Techniques
Gather Victim Host Information (4)	Compromise Accounts (2)	Exploit Public-Facing Application	Container Administration Command	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (2)	
Gather Victim Identity Information (3)	Compromise Infrastructure (7)	External Remote Services	Deploy Container	Boot or Logon Autostart Execution (14)	Boot or Logon Autostart Execution (14)	Build Image on Host	Credentials from Password Stores (3)	
Gather Victim Network Information (4)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Boot or Logon Initialization Scripts (8)	Boot or Logon Initialization Scripts (3)	Debugger Evasion	Exploitation for Credential Access	
Gather Victim Org Information (4)	Establish Accounts (3)	Phishing (2)	Inter-Process Communication (8)	Browser Extensions	Create or Modify System Process (8)	Doobfuscate/Decode Files or Information	Forced Authentication	
Phishing for Information (2)	Obtain Capabilities (4)	Replication Through Removable Media	Native API	Compromise Client Software Binary	Domain Policy Modification (2)	Deploy Container	Forge Web Credentials (2)	
Search Closed Sources (2)	Stage Capabilities (4)	Supply Chain Compromise (2)	Scheduled Task/Job (3)	Create Account (2)	Escape to Host	Direct Volume Access	Input Capture (4)	
Search Open Technical Databases (3)		Trusted Relationship	Serverless Execution	Create or Modify System Process (4)	Event Triggered Execution (14)	Execution Guardrails (1)	Modify Authentication Process (2)	
Search Open Websites/Domains (3)		Valid Accounts (4)	Shared Modules	Event Triggered Execution (14)	Exploitation for Privilege Escalation	File and Directory Permissions Modification (2)	Multi-Factor Authentication Interception	
Search Victim-Owned Websites			Software Deployment Tools	External Remote Services	Hijack Execution Flow (4)	Hide Artifacts (18)	Multi-Factor Authentication Request Generation	
			System Services (2)	User Execution (3)	Process Injection (2)	Impair Defenses (9)	Network Sniffing	
			Windows Management Instrumentation	Hijack Execution Flow (12)	Scheduled Task/Job (8)	Indicator Removal (3)	OS Credential Dumping (8)	
				Implant Internal Image		Indirect Command		
				Modify				

Source: <https://attack.mitre.org/>

Techniques: describe specific tactics and methods used by attackers to compromise systems and steal or manipulate information

Categories: type of attack or activity being performed

Mitigate risks of an outbreak by:

- Staying current with the latest detected vulnerabilities and attacks
- Reviewing Common Vulnerabilities and Exposures (CVE) reports
- Consulting trusted cybersecurity websites
- Subscribing to services offered by cybersecurity vendors

Outbreak alert services:

- Identify security gaps and weaknesses
- Gather threat intelligence from:
 - Global threat sensors
 - Malware analysis and artificial intelligence (AI)
 - Predictive analytics

What Does an Outbreak Alerts Service Do?

Outbreak Alerts include:

- A narrative of the attack, its timeline, and affected technologies
- A comprehensive list of solutions and subscriptions to break the attack sequence and tools for threat hunting
- A list of related resources and research

Module 3: Social Engineering

Social engineering: the act of manipulating people to gain advantage, often at the expense of those targeted, a wide range of attacks that leverage human emotions to manipulate a target, aims to steer the target in a direction prescribed by the orchestrator and often to the detriment of the target

Social Engineering Goals:

- Disclosing confidential information
- Transferring money
- Influencing a person or persons to think in a certain way

Characteristics of Social Engineering:

- The aim is to achieve an outcome desirable to the orchestrator
- The method is emotional manipulation

Signs to Spot a Social Engineering Attack:

- An emotional plea that leverages fear, curiosity, excitement, anger, sadness, or guilt
- A sense of urgency around the request
- An attempt to establish trust with the recipient

Social Engineering Attacks-Electronic Media Agnostic

- Quid pro quo: one thing for another, for example, a service such as tech support, is offered in return for information, such as user credentials
- Pretexting: a situation devised to invoke an emotional response in the target, for example, a person receives a call from a loved one who needs bail to get out of jail
- Baiting: an enticing situation that tempts you to act, for example, you discover a USB drive in the parking lot with an enticing label

Types of Social Engineering Attacks:

- Scareware: also known as a rogue attack, instilling fear through misinformation
- Watering hole: targeting/compromising a site that the target frequents
- Honeypot trap: attracting the target with something enticing
- Tailgating: exploiting social conventions to gain access to a physical facility or access-controlled room

Insider threat: an individual or individuals who work for an organization or have authorized access to its networks or systems and who pose a physical or cyberthreat to the organization, there are two types of insider threats; those who unintentionally assist bad actors because of human error or carelessness, and those who act maliciously.

Malicious insiders: also known as turncloaks, actions include espionage, fraud, intellectual property theft, sabotage

Types of Insider Threats:

- Collaborator: an insider who is working with an outside third party, malicious
- Lone Wolf: an insider who works alone, malicious
- Pawn: an insider who is being manipulated by a bad actor, negligent
- Mole: an outsider who pretends to be an insider, negligent
- Goof: an employee who believes they are exempt from their organization's security policies and bypasses them, negligent
- Turncloak: an employee who actively turns on their employer, malicious

Physical & Digital Threat Vectors

- Smishing: A phishing-type of attack using SMS or texting, it can be spam and distributed to everyone, or can be directed to a specific person or group.
- Spear Phishing: A social engineering attack that uses email to target a specific individual or group with the intent of stealing confidential information or profiting in some way. Generally, the individual or group has a lower profile than those targeted in a whaling attack. For example, an attack targets an IT manager as opposed to the CEO.
- Whaling: A form of phishing attack that uses email to target a high-ranking person or group. Examples are an executive officer within an organization or the board of directors.
- Vishing: A phishing-type of social engineering attack that takes place over a telephone or mobile device. Like smishing, it can be spam and sent to everyone, or it can be directed at a specific person or group.
- Pretexting: An attack that involves a situation or pretext devised to invoke an emotional response in the target, such as a bad actor pretending to be a friend or loved one in need.
- Watering hole: A form of cyberattack that targets groups of users by infecting websites that they commonly visit, or the bad actor may form relationships through social media sites with persons associated with the targeted organization.

- Tailgating: A type of social engineering attack in which an unauthorized person gains physical access to a restricted area by following someone who is authorised,
- Eavesdropping: Listening in on a conversation where confidential information is discussed. Digitally speaking, eavesdropping refers to network snooping or sniffing.
- Shoulder surfing: Uses direct observation techniques, such as looking over someone's shoulder to get information.
- Dumpster diving: Looks for information in someone else's garbage or recycle bin, or it could be a printer room where confidential information is printed.

Personal Actions to Protect an Organization's Assets

- Learn organization's policies
- Do not share proprietary information
- Secure all confidential data
- Do not allow tailgating
- Do not expose login credentials
- Patch your devices
- Do not disable endpoint security and controls
- No shortcuts of security policies

Network Actions to Protect an Organization's Assets

- Define, document, and disseminate
- Provide training
- Promote a culture of security awareness

Cyber fraud: A social engineering technique, malware, and other type of deception that is used to defraud or take advantages of a person or organization for financial or personal gain

Cyber scams: A type of fraud, but they are generally classified as petty or not as serious as cyber fraud

Examples:

- Copycat government websites: phishing, spear phishing, or other variant are used to provide a link to a fake government site, usually with the intention of stealing the user's credentials or credit card information
- Dating & romance scams: legitimate dating websites, social networks, and chatrooms are leveraged, to get personal details or money from people

- Holiday fraud: online holidays and accommodations are offered to customers that are not available or do not exist
- Mandate fraud: occurs when a bad actor hacks an email transaction such as one between a customer and a vendor, where the bad actor sends a duplicate invoice with the bad actor's bank account information and requests payment
- Pharming: traffic from a legitimate website is redirected to a fake one such as an e-commerce or banking site
- Greeting card scams: sending a malicious greeting card to a person on their birthday, or during an important holiday such as christmas or easter

Online influence campaigns: large-scale efforts to shift public opinion. Such campaigns are generally executed in bad faith and seek to promote a false narrative. These campaigns are often carried out by groups with high levels of capability, up to and including nation-state actors

1. The bad actor creates fake user accounts of social media platforms
2. The bad actor creates content to promote a given narrative
3. They post this content as fake users on numerous social media sites
4. Real people see the content and begin to share it
5. After reaching a certain threshold, mass media picks up the story, further amplifying the narrative

Module 4: Malware

Malware: malicious software that disrupts, damages, or gains unauthorised access to a computer system

Symptoms of a Malware Infection:

- Degraded performance, computer devices become sluggish
- Pop-up windows, unwanted pop-up windows appear
- Applications automatically launching or shutting down
- Applications not launching, failing to load
- Accounts locked, crashes, or logs out unexpectedly
- Computer crashing, shutting down expectedly
- Mass emails sent from email account, emails sent that you did not send
- Changes to homepage or browser settings, unexplained changes to homepage or browser settings

Virus: malicious code or programs invoked by a user, that attach themselves to applications, and are designed to spread to other devices on the network

Common Virus Types:

- Resident: infects applications when they are opened
- Non-resident: infects executable files when they are not running
- Multipartite: infects many computers, remains in computer's memory, goes on to infect more drives by altering the content of applications
- Direct action: accesses computer's main memory and infects all applications and files (located in the autoexec.bat path or the autostart registry path) before deleting itself
- Browser hijacker: person who changes the browser settings and functionality (technically not a virus as it does not infect files)
- Overwrite: virus that can delete and replace data in files with their own content or code
- Web scripting: attacks web browser security, allows for injection of malicious code into the browser
- File infector: overwrites files when they are opened
- Network: cripples networks and spreads to devices connected to the computer network
- Boot sector: targets the master boot record (MBR) and injects into the hard disk partition table then moves into the main memory when a computer restarts
- Worm: does not need a host system, can spread between systems and networks without user action
- Rootkit: a collection of malicious computer software designed to enable access to a computer or an area of its software that is typically inaccessible, masks itself, operates near or within the kernel of the operating system, and cannot self-replicate or spread across systems
- DLL injection: allows the attacker to execute malicious code by replacing legitimate DLL files with malicious ones, difficult to detect or prevent because it often involves the use of legitimate files and processes
- Driver manipulation: changes or replaces driver software that allows the operating system to communicate with hardware devices
- Keylogger: records every keystroke the user inputs to gain confidential information
- Potentially unwanted program (PUP): unwanted program that the user may have unknowingly downloaded
- Spyware: tracks computer activity and data
- Adware: hides on a device and displays ads

- Dialer: uses dialing features to run up phone bills
- Adversarial artificial intelligence: malicious input designed to confuse neural networks
- Ransomware: encrypts information on a computer, which is restored only after paying a ransom
- Trojan horse: a virus disguised to look like something it is not
- Dropper: a type of trojan horse virus designed to install malware on a computer
- Rogueware/scareware: misleads user into believing malware is on their computer, prompts them to pay or download antimalware to fix the issue
- Botnet malware: infects a host through a command and control server, a collection of infected computers controlled by a c&c server is known as a botnet
- Cryptojacking: the illegal use of a user's computing resources to mine cryptocurrency

Attack vector: a method that a bad actor uses to illegally access or inhibit a network, system, or facility, has three components; a vulnerability, a mechanism, and a pathway, where a pathway (eg social media platform) enables a mechanism (eg malware) to access a target (eg user)

Attack surface: represents the total number of entry points that the vector creates to gain unauthorized access to the target

Command and control server: acts as a central hub to send instructions to infected devices, download new malware, and steal data from target networks

A bad actor controls an infected computer, i.e., bot or zombie, using a command-and-control (C&C) server, which sends commands to systems compromised by bot malware, and then receives stolen data.

Examples:

- Code injection: injects code into an application to change the way that it runs
- Shellcode: instructional code that takes control of a compromised computer, a set of instructions that executes a command in software to take control of or exploit a compromised machine
- Downloader: a trojan horse that installs itself on a computer and uses the internet to download malware

- Droppers: programs that extract files, typically malicious files, to a machine, a program designed to extract other files from its own code
- Easter egg: a hidden feature or code left behind by developers that could leave your network and data exposed to bad actors
- Logic bomb: a piece of malicious code left lying in wait on a computer that will execute under specific conditions
- Backdoor: an unauthorized way of gaining access to a computer system

Module 5: Cryptography and the Public Key Infrastructure

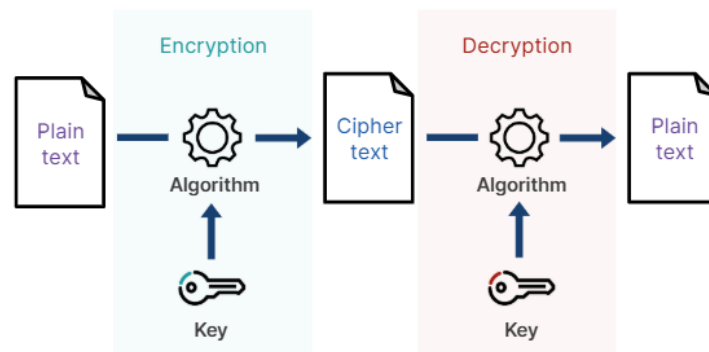
Cryptography: the study of writing or solving codes

Public Key Infrastructure (PKI): the implementation of cryptography on a computer network, an infrastructure composed of hardware, software, policies, and procedures that facilitates the management of public digital keys

Encryption: the process of converting plaintext to crypto text, making something that was readable, unreadable, ensures information stays private and confidential

Digital signature: ties the signer to the information signed, uses cryptography to produce a unique value that can be tied to a person, guarantees the integrity and authenticity of the data, can ensure non-repudiation (non-repudiation has legal implications, and means that the signer cannot deny having signed the information)

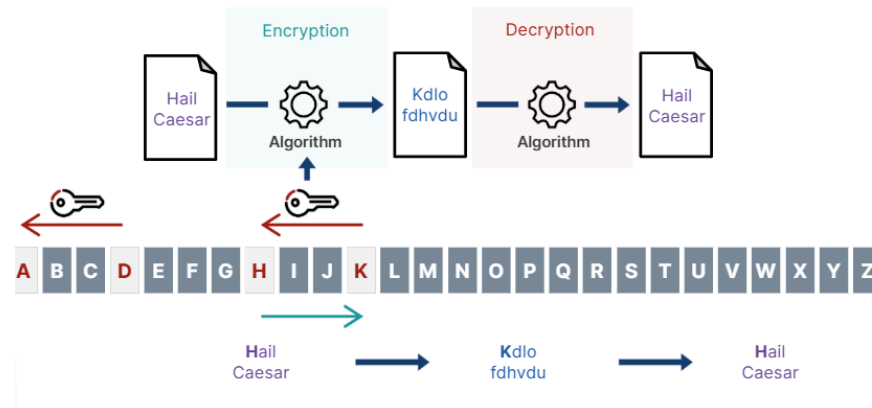
Cipher: a secret or disguised way of writing a code, cryptographic algorithms and digital keys are used as ciphers, allowing you to encrypt and decrypt information, and convert plaintext to ciphertext and back again.



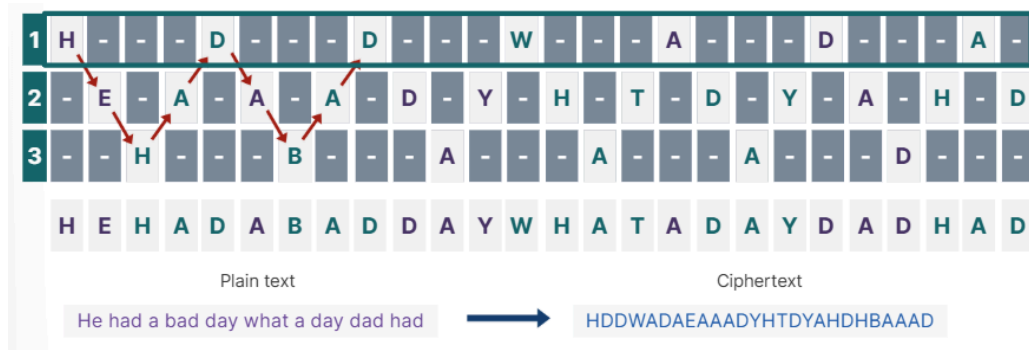
Algorithm: a finite sequence of rigorous, well-defined instructions, typically used to solve a class of specific problems or to perform a computation, algorithms are usually public information, and keys are usually secrets.

Types of Ciphers:

- Substitution Cipher: the letters of the plain text message are replaced by other letters, the number of letter shifts, i.e., the shared key, is required to decrypt the message

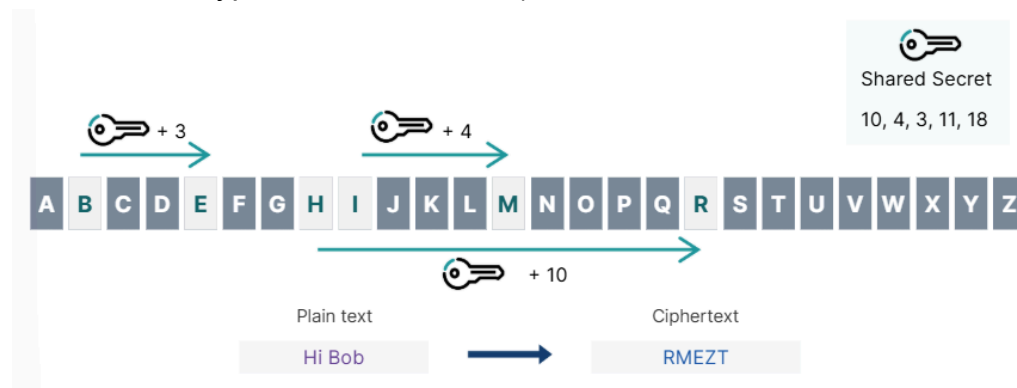


- Transpositional Cipher: rearranging the letters, more complicated than the substitutional cipher, an example is the rail fence method, the plaintext message is written in a zigzag form, when enciphering the plaintext, the letters are taken row by row, the receiver of the ciphertext would have to know the number of rows, i.e., the shared key



- The One-Time Pad Cipher: introduces randomness to the substitution method, known as the one-time pad because the shared key is used only one, uses a different value for each letter in the message, 26 possible combinations for each letter of the message, almost 12 million possible combinations for a five-letter message, without a computer, it is impossible for break using a brute force attack (trying every possible combination to break a code or password), the randomness of the die ensures that there

are no repetitive patterns and that there is an equal chance of converting a plaintext letter to any one of the twenty-six letters of the alphabet (encrypt, clockwise; decrypt, counterclockwise)



Ciphers Used by Computers:

- Stream Cipher: encrypts a stream of plaintext data one bit or byte at a time, examples are FISH and RC4 (Rivest Cipher), faster than block ciphers
- Block Cipher: break the plaintext into blocks for encryption, the size of the block is dependant upon the size of the key, if the key is 256 bits, then the blocks to be encrypted will also be 256 bits, if the size of the message is one megabyte then the message would be divided into multiple blocks each one 256 bits in size, examples are Data Encryption Standard (DES), 3DES, and Advanced Encryption Standard (AES), and Blowfish

What is a digital key?

In cryptography, a digital key is a value, which can be expressed alphanumerically, that is used to perform cryptographic operations. Digital keys have an expiry, which can range from a couple of years, to a couple of seconds. Digital keys can be private or secret, or public, such as for digital certificates. Digital keys are used for:

- Digital signatures
- Message authentication code (MAC)
- Encryption
 - Flow of information between two devices
 - Bulk stationary data
 - Small piece of data, such as a digital key

Public keys are often 1024, or 2048 bits or larger. Because of their large size they are often used to encrypt small pieces of data, like another key, or a hash of data. Smaller keys in the 128 to 256 bit range are used to encrypt bulk data. Thus the type or size of the key is determined by the type of cryptographic operation. If you are

encrypting a key to safely transfer it to another entity, use a larger key. If you are encrypting a stream of data where performance is critical, use a smaller key. The length and complexity of a key impacts its strength.

Key stretching: method to strengthen keys or passwords that are either too short or predictable, the process involves feeding the key or password into a type of hashing algorithm, to produce an enhanced key or password. Examples of stretching algorithms are password-based key derivation function two (PBKDF2), and BCrypt (default algorithm used for key stretching in OPENBSD and Linux distributions). When BCrypt is used, the key or password is hashed multiple times before a 128-bit salt is added, then the combined value is hashed once more. A salt is a random value added to another value to increase entropy (randomness).

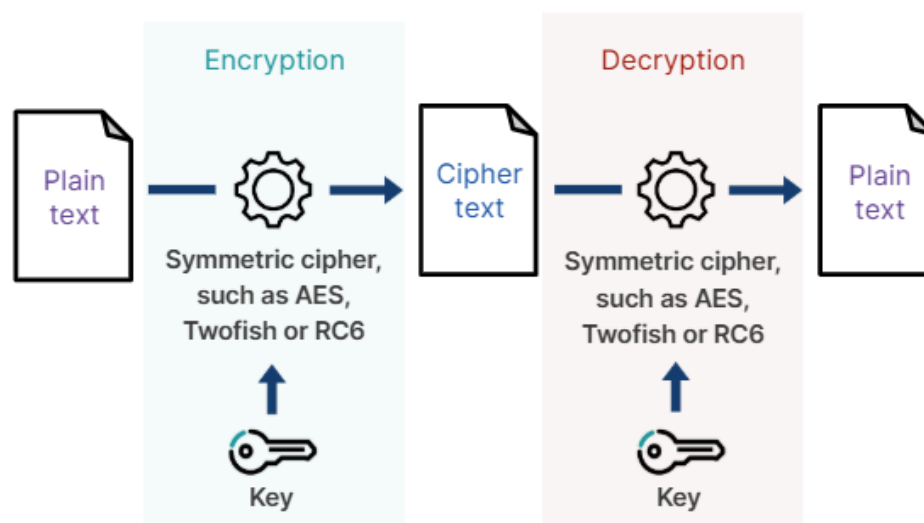
Symmetric Algorithm: a cipher used to encrypt and decrypt data using the same key. Examples include Data Encryption Standard (DES), 3DES, International Data Encryption Algorithm (IDEA), Advanced Encryption Standard (AES), Rivest Cipher (RC4, RC5, RC6), Blowfish/Twofish.

Advantages: Faster to encrypt and decrypt than asymmetric cryptography because symmetric keys are shorter, efficient to encrypt and decrypt large amounts of data

Disadvantages: Relies on a secret key that needs to be protected

How Does Symmetric Cryptography Work?

The same cipher and key is used to both encrypt the plaintext to ciphertext, and decrypt the ciphertext back to plaintext.



Asymmetric Algorithm: a cipher used for cryptographic operations using a pair of mathematically related keys (public and private keys). They can do all, or some, of these operations:

- Encryption
- Key exchange
- Digital signature

Asymmetric algorithms and cryptography are also known as public-key algorithms and cryptography. Some asymmetric algorithms are:

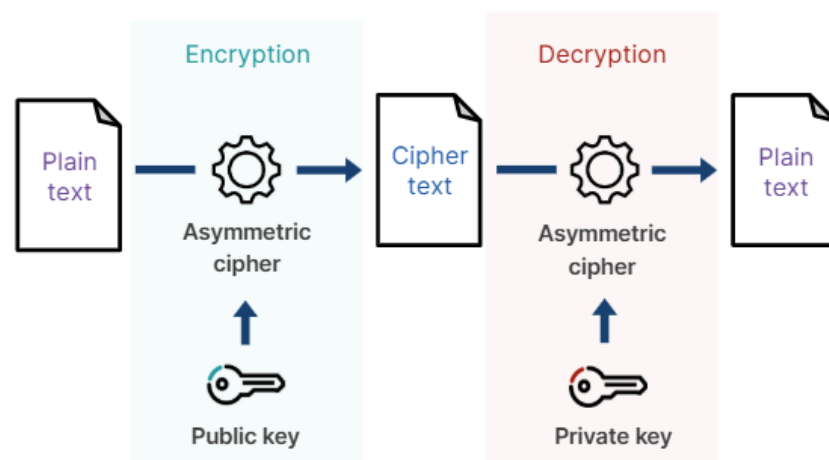
- Diffie-Hellman
- Rivest, Shamir, and Adleman (RSA)
- Elliptic Curve Cryptography (ECC)
- Pretty Good Privacy (PGP) and GPG
- Digital Signing Algorithm (DSA)

Advantages: Increased data security, as users do not share their private keys. The public key encrypts and the private key decrypts.

Disadvantages: Operations are relatively slow when compared to symmetric cryptography. Not efficient to encrypt and decrypt large amounts of data.

How Does Asymmetric Cryptography Work?

During encryption, the sender's crypto application converts the plaintext to ciphertext using the recipient's asymmetric public key and an asymmetric cipher. During decryption, the recipient's crypto application converts the ciphertext to plaintext using the recipient's private decryption key and the same asymmetric cipher that the sender used.



Combining Symmetric and Asymmetric Cryptography

When symmetric and asymmetric cryptography are combined, the disadvantages of both are remedied.

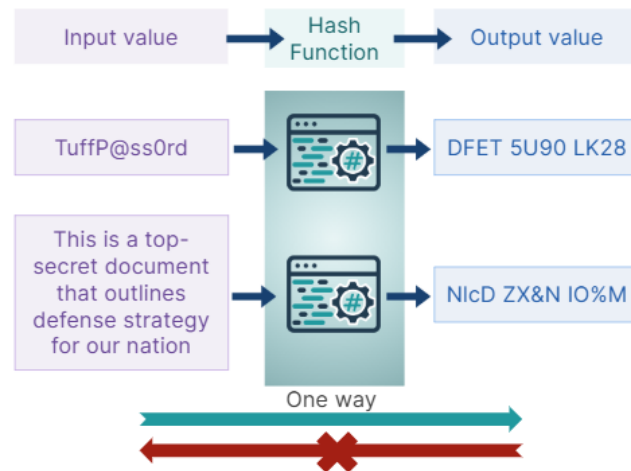
How do we securely send the symmetric key to the receiving party?

Alice sends an encrypted message to Bob.

1. In the first step of encryption, Alice's crypto application generates a one-time symmetric key, and, together with a symmetric algorithm, encrypts the message.
2. Next, the application retrieves Bob's public encryption key, and uses this key, together with an asymmetric algorithm, to encrypt the symmetric key.
3. Next, the encrypted message and key are sent to Bob.
4. In the first step of decryption, Bob's crypto application retrieves the private key from his secure key store. The private decryption key, along with the same asymmetric algorithm Alice used decrypts the symmetric key.
5. Next, the symmetric key, together with the same symmetric algorithm Alice used, are used to decrypt the message.

Hashing: the process of converting data of an arbitrary size to a unique value of a fixed size

1. Output value is a fixed length
 - a. Determined by the hashing algorithm
 - b. Denies the bad actor information about the nature of the input data
2. Output value is unique for every input value
 - a. Detects changes to input data when output value is different
 - b. Denies the bad actor the ability to alter data and get away with it
 - c. Avoids collisions
3. Hashing is nonreversible and one way
 - a. Cannot reproduce the input value by using the output value
 - b. Denies the bad actor using the output value to determine the input value



Hashing and asymmetric cryptography are needed to produce a digital signature
Digital signatures ensure:

- Data integrity
- Authentication of the signer
- Non-repudiation

Producing a Digital Signature-Signing Process

1. The information that needs to be signed is hashed, producing an output hash value.
2. The asymmetric private signing key associated with the signer encrypts the output value using an asymmetric algorithm. This encrypted output value is called a digital signature.
3. The digital signature is attached to the information.

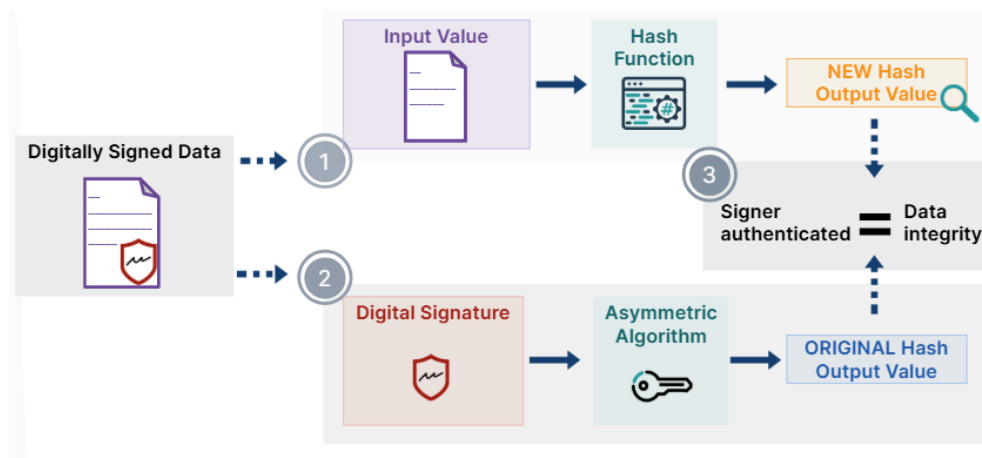
In order to verify the signed information, you require the corresponding public verification key. In asymmetric cryptography, public keys are written to certificates. Certificates are issued and signed by a Certification Authority (CA). In addition to the public key, the certificate bears the owner's name. The verification certificate could be retrieved from a repository by the receiver, or it could be attached to the signed document.

Producing a Digital Signature-Verifying Process

1. The receiver's application hashes the information producing a new output value.
2. After verifying that the signer's verification certificate is valid, the public key decrypts (in other words, verifies) the digital signature.

3. The verifier compares the new output value to the original output value. If they are the same, then you know that the information has not changed.

Because the public key successfully decrypts the digital signature and because the owner's name of that key is written in the certificate, you can confirm the authenticity of the signer.



Common Hash Functions:

- Message digest five (MD5) and MD6
- Secure hashing algorithm one (SHA-1), SHA-2, and SHA-3
 - SHA-2 includes SHA-224, SHA-256, SHA-384, and SHA-512
 - SHA-3 various output lengths
- Microsoft LANMAN and NT LAN Manager (NTLM) algorithm
- HAVEL and RIPEMD

Common Attacks Against Hashing:

- A brute force attack is more effective if the bad actor has clues about the nature of the input data
- The bad actor tries every combination, until they produce the value of the original hash output
- Birthday attack
 - Easier to find any two matches if you don't care which two they are
 - Exploits the mathematics being the birthday problem in probability theory
- Defending against brute force attacks
 - Increase the size of the hash output length
 - Key stretching: a technique used to make a weak key, such as a password, more secure by adding resources. The resources could

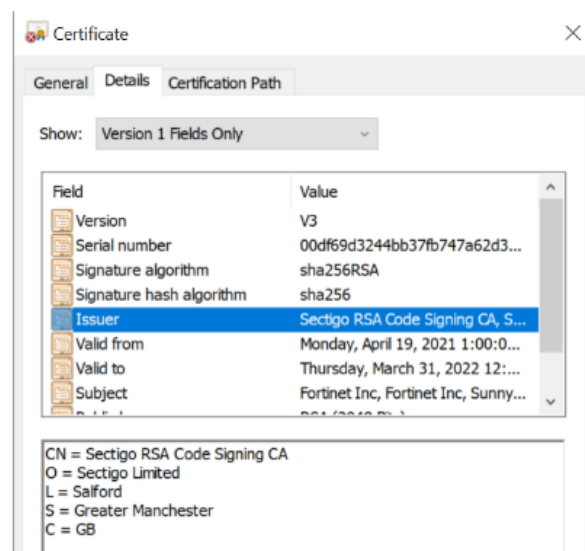
be a combination of adding a random value (called a salt value) to the key and hashing the combined values

What is a Public Key Infrastructure?

Public key infrastructure (PKI) is an ecosystem comprised of policies, procedures, software, and hardware, needed to create, distribute, store, use, and revoke digital certificates. Four entities compose a PKI; Certification Authority (CA), Registration Authority (RA), Directory Server, and End Entity.

What is a digital certificate?

A digital certificate is an electronic document issued and signed by a trusted entity, such as a CA. It contains the name of the certificate holder, and may or may not contain a public key. The CA binds the identity and key using a digital signature. The certificate is trusted because it is signed by a trusted entity. The CA's private key provides the trust.



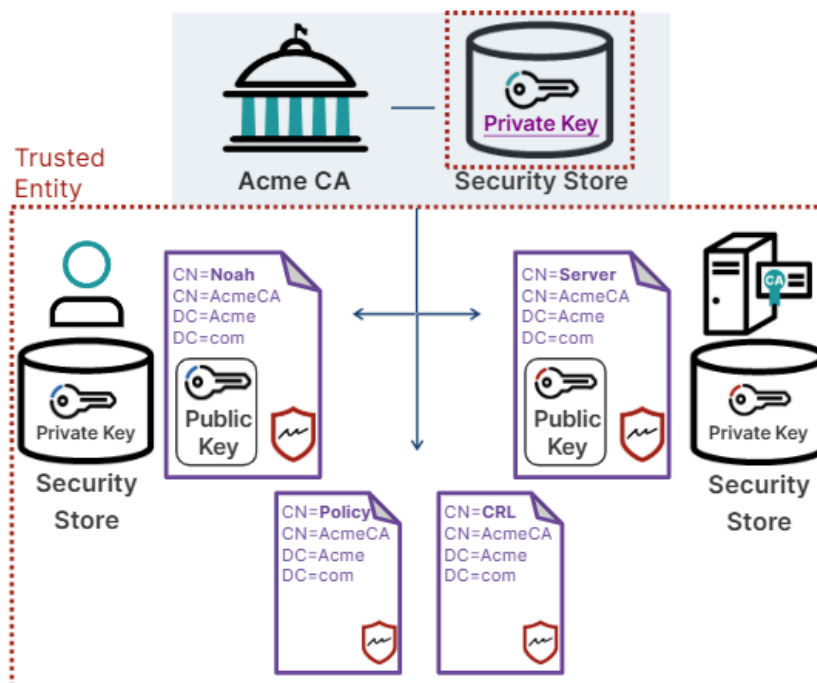
- Certificates with public keys
 - Encryption
 - Verification
- Certificates without public keys
 - Policy
 - Certificate Revocation List (CRL) [lists revoked end entity certificates]
- Certificate standard is X.509 version 3.

Common fields found in certificates are:

- Serial number
- Algorithms
- Validity period
- Issuer name
- Subject name
- Key value
- Key usage

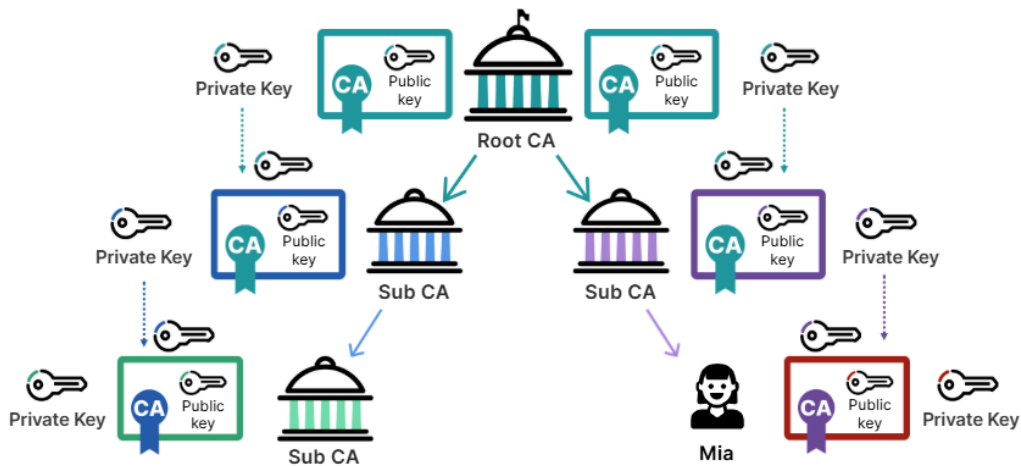
CA primary functions

- Issue certificates to end entities and to the system to help manage the following certificates:
 - CRL
 - Policy certificates
- Establish an ecosystem of trust. Trust hinges on the CA's private key.



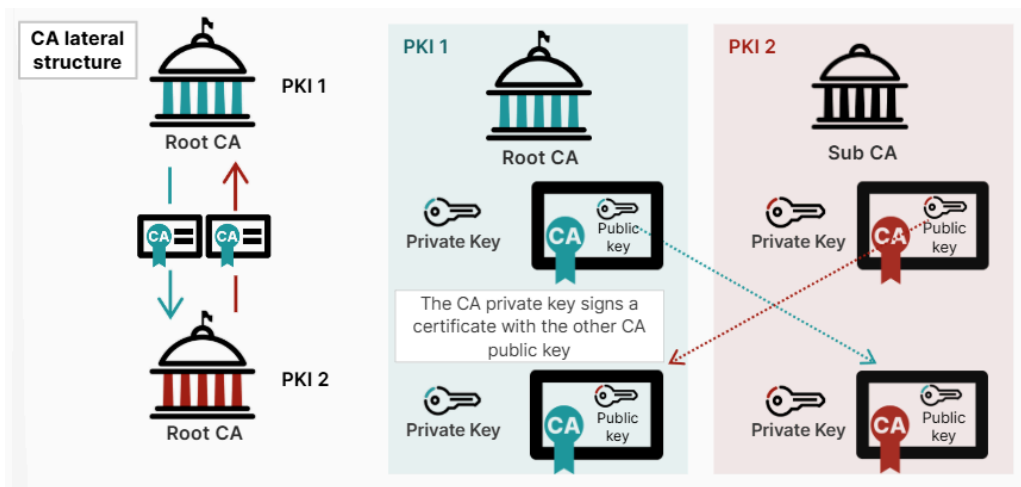
Why trust the private key?

- Relationship with a trusted entity
- A legal framework supports the trust:
 - Proof of the highest security standards
 - High-assurance versus low-assurance CA's



In a hierarchical environment, there would be one root CA and one or more subordinate CAs. The root CA is the source of trust and the subordinate CAs issue certificates to end entities. In turn, a subordinate CA can have a subordinate CA and so on, creating a deeper hierarchy.

It is also possible for the CA in one PKI to trust the CA of another PKI by cross-certifying. This is a lateral structure because the trust relationship exists between two CAs of different PKIs. In the process of cross-certifying, cross certificates are created that allow users of one PKI to trust the users of another PKI and vice versa. The cross-certification can take place between a root or subordinate CA from one PKI and a root or subordinate CA from another PKI.



Storing Certificates in the Directory Server

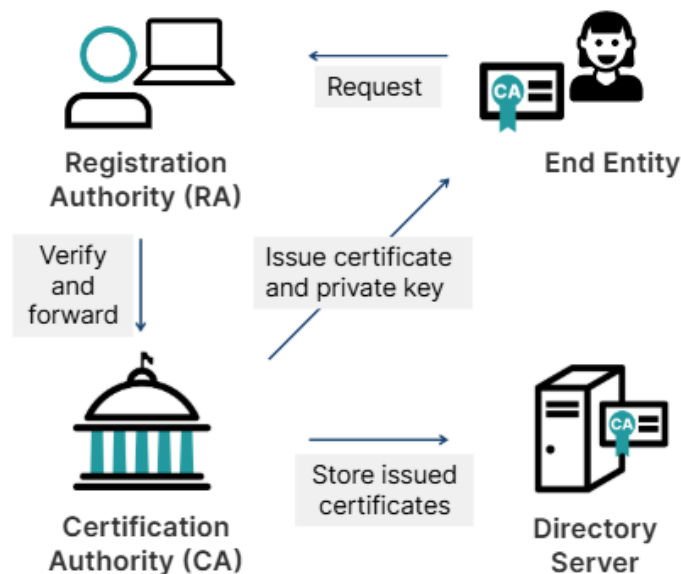
1. The sender's application sends the certificate along with the signed document to the recipient
2. The recipient's application retrieves the sender's certificate from a server

PKI standards anticipate that end entities would retrieve certificates from:

- X.500
- Lightweight Directory Access Protocol (LDAP)-compliant directory server: stores not only user and device certificates, but all of the certificates of the PKI, including:
 - Policy
 - CRL
 - Authority Revocation Lists (ARL): lists revoked CA certificates and revoked cross-certificates
 - Cross-certificates
 - CA certificates

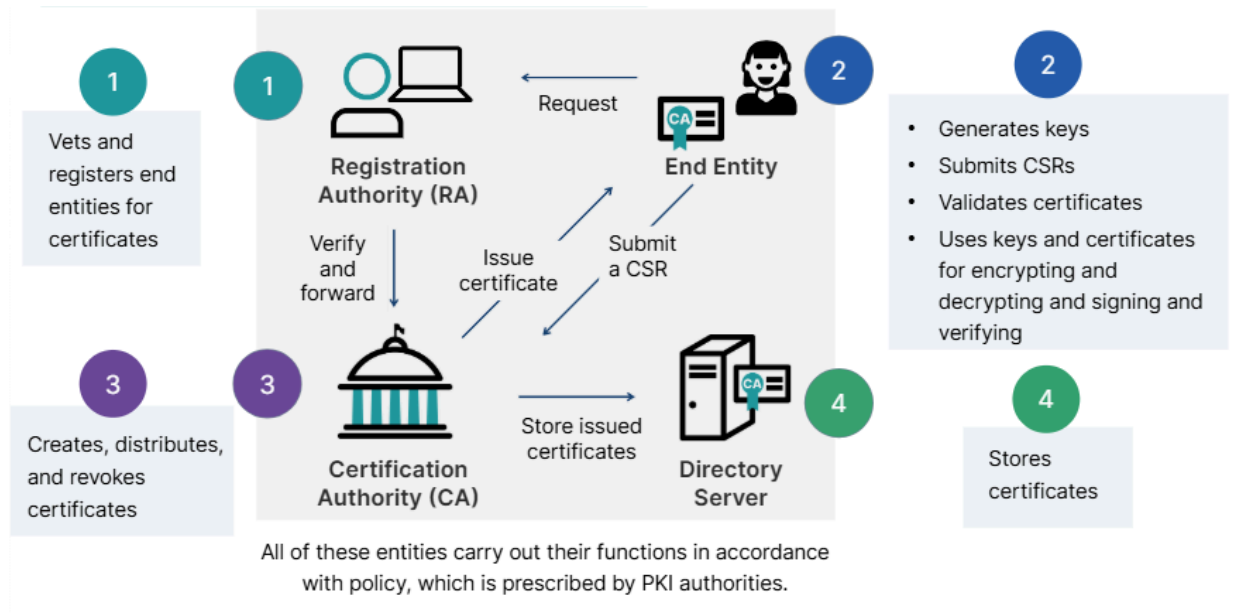
A registration authority (RA) is a function for certificate enrollment used in PKIs. The RA verifies and forwards certificate requests to the CA:

- Certificates can be issued to persons, devices, and applications
- Registration can occur online or in person
- Applying for a certificate is similar to applying for a car license
- The degree of vetting may be dependent upon the assurance level of the CA



Cryptographic endpoints should be able to:

- Generate keys
- Generate and submit a certificate service request (CSR)
- Validate certificates
- Use keys and certificates for encrypting, decrypting, signing, and verifying



An Online Certificate Status Protocol (OCSP) responder is used to check the revocation status of certificates.

Harvest now, decrypt later: bad actors intercept sensitive data today, store it, and decrypt it in the future when quantum computers are advanced enough

What is quantum computing?

A new approach to calculation that used principles of fundamental physics to solve extremely complex problems very quickly. It uses special units called qubits (Quantum Bit), based on quantum physics, to explore many possible solutions simultaneously and solve complex problems much faster than regular computers.

Bits vs. Qubits

Bit:

- The basic units of information used by a regular computer
- Can have only one of two values: 0 or 1

Qubit:

- The basic unit of information used by a quantum computer

- Can exist in a superposition of the states 0 and 1 simultaneously until it is measured

Superposition: a fundamental principle of quantum mechanics stating that a quantum system can exist in multiple states simultaneously until it is measured. For example, when a coin is lying flat, it is either heads (1) or tails (0), but when a coin flips in the air when tossed, it exists in a mix of 0 and 1 at the same time.

Quantum advantage: Qubits in superposition let a quantum computer evaluate many paths at once. This is the foundation of quantum advantages, and the main reason why quantum computing threatens classic cryptography designed for sequential processing

Factoring a 2048-bit number or solving a discrete logarithm would take a classical computer millions of years - it is computationally infeasible by design. The same problems become solvable with quantum computers. Peter Shor proved that a sufficiently powerful quantum computer can factor large numbers efficiently, and solve discrete logarithm problems.

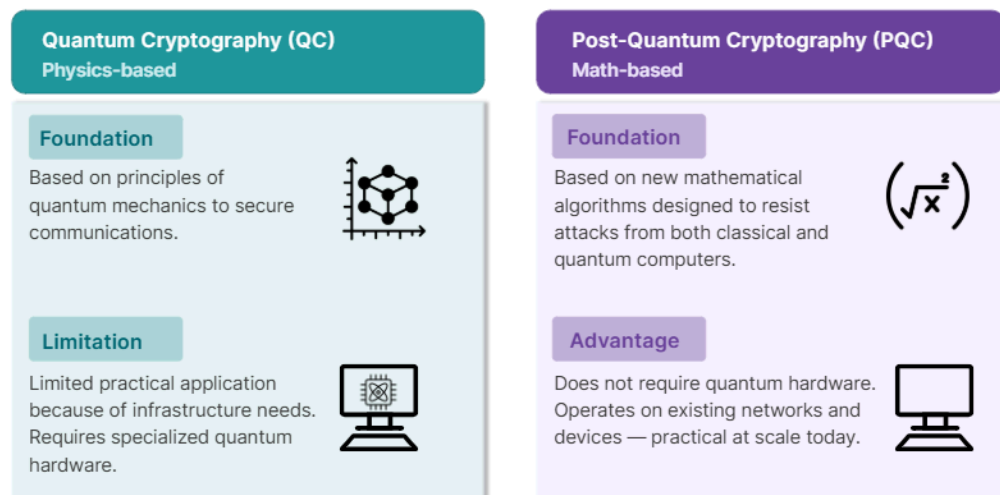
Public-key cryptography is broken, symmetric encryption is weakened, and administrative controls are mostly unaffected.

Browsing the web securely (HTTPS connection to a website)	Broken or at risk
Multi-factor authentication (local device)	Mostly unaffected
Encrypted email (S/MIME or PGP)	Broken or at risk
Verifying a software download (digital signature)	Broken or at risk
Using secure messaging apps (Signal, WhatsApp)	Broken or at risk
Encrypting files on a hard drive with AES	Weakened
Connecting a laptop to a company network using a VPN	Broken or at risk
Changing access control policies as a network administrator	Mostly unaffected
Storing passwords in a database using a hashing algorithm	Weakened
Storing data in a cloud backup encrypted with AES	Weakened

At the quantum level, particles exist in multiple states simultaneously, making their behaviour inherently unpredictable. Photons can be configured to represent binary data, forming the foundation of quantum-encrypted transmission. Any unauthorized attempt to intercept a quantum-encrypted message physically alters it, making unauthorized access not just difficult, but easily detectable.

Quantum Key Distribution (QKD): a cryptographic protocol that enables two parties to generate a shared encryption key using the principles of quantum mechanics. As quantum states cannot be fully replicated, the data cannot be copied. This, in theory, makes quantum cryptography unbreakable.

Post-quantum cryptography (PQC): cryptographic algorithms designed to remain secure even if large-scale quantum computers become practical.



These four approaches aim to provide the same services as today's public-key cryptography, such as encryption, key exchange, and digital signatures, but with algorithms that remain secure in a quantum-computing era:

- Lattice-based: security rooted in the geometry of high-dimensional grids
 - Complex lattice problems: finding the shortest vector in a high-dimensional lattice is computationally impossible
 - Multidimensional complexity: more dimensions exponentially expand the search space, hardening security
 - Efficient and future proof: strong candidates to replace current public-key systems like RSA and ECC
- Hash-based: rely on the security of cryptographic hash functions
 - One-way hash functions: easy to compute, impossible to reverse
 - Deterministic: the same input always produces the exact same hash, every single time
 - Avalanche effect: change even one letter and the output hash looks completely different
- Code-based: rely on difficulty of decoding random linear error-correcting codes

- Hard decoding problem: decoding a random linear code without the secret key is computationally intractable
- Hidden pattern; the authorized user holds the pattern key. An attacker only sees scrambled random pieces
- Efficient and future proof: the McEliece cryptosystem was proposed in 1978. Despite decades of intense study and significant cryptanalytic effort, no one has broken the core hard problem - giving it one of the longest security track records in all of cryptography
- Multivariate: based on the difficulty of solving systems of many multivariate polynomial equations over finite fields
 - Hard multivariate polynomial equations: solving many polynomial equations over finite fields is computationally infeasible, even for quantum computers
 - Public key: a set of multivariate polynomial equations. Anyone can see them, but solving them is the hard problem.
 - Private key: secret trapdoor information that makes the equations trivially solvable for the legitimate user only.

NIST Standardized PQC Algorithms:

- CRYSTALS-KYBER (expected to be standardized as ML-KEM): key establishment
- CRYSTALS-Dilithium (expected to be standardized as ML-DSA): digital signature
- SPHINCS+ (expected to be standardized as SLH-DSA): digital signature
- FALCON (expected to be standardized as FN-DSA): digital signature

These standards are intended to guide governments, industry, and software developers as they transition to quantum-resistant cryptographic systems. Standardization helps interoperability, but dependence on a small set of algorithms increases systemic risk. Cryptographic agility and hybrid approaches help reduce that exposure.

Module 6: Secure Network

What is a Secure Perimeter?

A secure perimeter is a form of protection that consists of devices or techniques added to the edge of a managed network. Taking into consideration different LANs, which interconnect to create a WAN, the trusted zone for a company is the IT managed

portion of devices and applications. A remote office device can also be part of a secure perimeter if it connects to the trusted zone using a secure remote access. Everything inside the managed network is protected. Everything outside the secure perimeter is considered untrusted. Specific devices and applications that create the secure perimeter protect the trusted zone. The secure perimeter has specific authorization and authentication applications that protect and provide confidentiality, while filtering traffic to the trusted zone.

The secure perimeter can filter traffic at different OSI layers. At the data link layer, a secure perimeter device can perform Media Access Control (MAC) filtering. For example, the IT manager can create an access control list (ACL), a defined list of devices with known addresses in the trusted network. Therefore, the secure perimeter allows only corresponding devices with known MAC addresses to pass through the network.

At the transport layer, a secure perimeter device can perform packet filtering. Packet filtering allows or denies packets based on a configured set of rules. Packet filtering can be stateless, where each packet is checked based on its IP addresses, source and destination ports, and protocol. In contrast, packet filtering can also be stateful, where the security device keeps track of the 5-tuple (refers to the source IP address and port number, destination IP address and port number, and the protocol in use. It characterizes and allows tracking of a TCP/IP connection) check and the TCP/IP connection state. Therefore, the return traffic is validated only if it matches the corresponding incoming traffic.

A secure perimeter device can also perform network address translation (NAT) filtering at the transport layer. NAT filtering can translate a public IP address to a private IP address, and a private IP address to a public IP address. A translation is required to access the internal resource from the internet, because it usually protects a private network (a network that has its own private address space of IP addresses), an IP, and sometimes a port.

At the application layer, a secure perimeter device can provide proxy filtering. Through the man-in-the-middle mechanism (intercepts communication and splits it in two. All packets are then received by proxy. The packets can then be modified, before the proxy forwards them to the other end), this gateway hides the internal user from the internet. At the same layer, a secure perimeter device can also act as an application layer gateway (ALG). An ALG inspects the packets up to layer seven, allowing the secure perimeter device to open TCP/UDP data ports dynamically. For example, protocols like FTP or SIP have a control connection that provides the port used for data

communication. The secure perimeter device opens this temporary port only for the corresponding sessions.

Limitations of Secure Perimeters:

Due to the emerging trend of remote working, along with the introduction of bring your own devices (BYOD), the internet of things (IoT), and the cloud working model, IT departments have a harder time dynamically updating the security perimeter. It is from these drawbacks that the zero trust principle, which is built upon the evolution of the secure perimeter, is widely used to ensure greater trust.

Secure Perimeter v/s Zero Trust:

Secure Perimeter: Trust, but verify. Anyone inside the perimeter is trusted, and anyone outside is not. Performs a verification at initial access using predefined rules and common policies,

Zero Trust Model: Never trust, always verify. Every user and device within a network is untrusted by default. Does not grant explicit and full access to anyone. Continuous verification with various fine-grained rules and adaptive policies. This microsegmentation uses the principle of least privilege access, and minimizes the attack surface, and prevents the chances for lateral movements, unlike the secure perimeter model.

What is the Zero Trust Security Model?

The concept behind the zero-trust security model is that trust must be explicitly derived from a mix of identity-based and context-based aspects.

The Three Core Principles of the Zero Trust Security Model:

1. Never trust, always verify, always authenticate a user or device to determine their identity, and verify what resources the user or device is authorized to access.
2. Implement least privilege, users and devices are granted access to only those resources that they need to complete their jobs or functions.
3. Assume your network is breached, take precautions, such as reducing the attack surface

Evolution of Network Security Architecture:

Perimeter Networks: closed, self-contained units with firewalls that act like drawbridges. Most endpoints and servers exist within the network perimeter. VPNs provide secure connections for remote users and between local area networks. Users provide credentials, usually a username, and password, to authenticate to the network. The network assigns roles to the authenticated users to control access to network

resources. However, if a user's credentials become compromised or if a user's device becomes infected, then malware can move laterally across the network infecting other devices and potentially exfiltrating valuable information.

Business Transformation: forcing networks to decentralize so that some network components remain on-premises, some are located in a private cloud, and others, in the public cloud. This transformation, plus the advent of BYOD, the internet of things, and an expanding remote workforce, has drastically enlarged the attack surface, and provided many more attack vectors.

The Never Trust Principle: trust is explicitly derived from a mix of identity and context-based aspects:

1. Identification Process:
 - a. Multifactor Authentication: an authentication method in which a computer user or device is granted access only after successfully presenting two or more pieces of evidence, or factors, to an authentication mechanism.
2. Context-Based Aspects:
 - a. Time and date: when business hours are distinguished from non-business hours to restrict access to resources or to demand an additional method of authentication, such as one-time password.
 - b. Geolocation: when alerts can trigger restrictions to resources based on the geographical location of the requestor.
 - c. Security posture: when restrictions are placed on a device that doesn't meet security requirements, such as updated patch, and anti-virus software.

Principle of Least Privilege:

1. Privileged access management (PAM): PAM is an information security mechanism that safeguards identities with special access or capabilities beyond regular users.
2. Define the protect surface: a process of identifying network resources, assessing the degree of confidentiality, and determining which roles require access to them.
3. Apply the Kipling method: the process of asking yourself a series of questions, such as who, what, when, where, why, and how when preparing to solve a problem

The Assume Breach Principle:

1. Prepare for the worst: following this process provides you with the opportunity to make various plans that can be invoked immediately after a breach.
2. Microsegmentation: segment the network into smaller sections to restrict the lateral movement of contagions.

Other Zero Trust Methods:

1. Zero Trust Access: a secure access method that supports zero trust security, uses:
 - a. Role-based access control: once a user is identified, they can be assigned a role that determines what resources they have access to. A user can be assigned more than one role. Examples of roles are:
 - i. Employee
 - ii. Guest
 - iii. Contractor
 - iv. HR Manager
 - v. IT Analyst
 - vi. Account Manager
2. Endpoint agent: for greater visibility and control of computer devices, endpoint software agents that support the zero trust model can supply the network with valuable information about the device, such as the operating system, patch level, installed software on the device, and so on. This information can be used to assess the level of risk the device might pose to a network.
3. Network access control (NAC): for headless devices, such as IoT, identifies the devices on the network, giving IT security greeted visibility and control.
4. Zero Trust Network Access (ZTNA): technology that establishes a secure session automatically between the end entity and the network regardless of location, while ensuring granular control over access to applications, and enforcing the precept of zero trust.

Benefits of Zero Trust Security:

- No trust
 - Trust must be proven through:
 - MFA
 - Risk measurement through a context-based assessment

- Least privilege access ensures tighter restrictions to access resources by users, devices, and applications
- Review access to assets by asking what, why, when, where, and how, reducing the attack surface and better protect the whole network
- Microsegmentation isolates a compromised device or network segment

Centralized Security Network Management: the act of gathering security-related data from various devices and applications into one central location.

Data gathering can be done through logs, simple network management protocol (SNMP), which collects and organizes information on managed devices, or an application programming interface (API), which is a software interface that allows two devices to communicate with each other. An API can also provide scripting possibilities, which can reduce manual tasks and human error.

The objective of centralized security network management is to provide a comprehensive view of the network security status through typical network management actions, such as configuring, controlling, operating, and diagnosing a security network.

In an expanding network, including more IoTs, remote users, and cloud environments, security administrators require dynamic and elastic centralized network security management. A possible solution can involve implementing data fabric.

Data Fabric Architecture: provides the possibility to monitor and manage data and applications wherever they are, while remaining centrally governed.

Like a needle and thread, data fabric stitches together different parts of the security network to create a tapestry. As data gathers more data, it uses AI, to help consolidate more relevant data to improve decision-making.

For example, repetitive tasks are initially performed manually. Over time, AI observes these tasks and not only begins to automate them, but through machine learning, also makes recommendations.

Benefits of Centralized Security Network Management:

- High-level view and broad visibility of security in the network
 - Centralized reports and simplified analyses of security events
 - Avoid security issues
 - Reduce incident response times
 - Minimizes disruptions

- Device integration
 - Centralized definition of configurations and policy orchestrations
- Reduction in number of repetitive/manual tasks
- Easier maintenance
 - Application of patches
 - Updates to monitoring
 - Improved protection of the entire digital attack surface
 - Improved risk management
- Easier capacity and performance forecasting from a central point
- Easier compliance audits

Network Segmentation: divides a network into smaller, isolated segments. This allows IT managers to better control and protect a large network from breaches or malfunctions. In a network, devices and applications with similar functions are grouped together for easier management.

An example of segmentation involves servers that are accessed from the internet. A company may need some server on their network to be available to the internet, but not want to expose the rest of their network. In this case, the servers that you want to be accessible from the internet are placed in a demilitarized zone (DMZ) [a segmented part of an organization's network that has external facing services to an untrusted network, like the internet], separated from the rest of the internal network. Therefore users on the internet can access these servers without gaining access to the rest of the network. The traffic moving in and out of the DMZ is classified as north-south traffic. The DMZ can be compartmentalized even further through micro segmentation. When microsegmentation is used, each resource (hosts, users, applications), is uniquely identified and protected. This identification and protection is achieved through zero trust. The traffic that moves across a specific data center or cloud network is called east-west traffic.

A network can be segmented into physical and logical segments. Physical segmentation uses firewalls and hardware like routers and switches to break networks down into multiple physical sections or subnets. Logical segmentation breaks networks into smaller more manageable sections and often does not require an organization to invest in new hardware or wiring.

These different methods of segmentation are performed at the various levels of the OSI model.

At the data link layer, a logical segmentation approach is deployed using virtual local area networks (VLANs). VLANs provide a way for groups of devices to communicate with one another through switches, as if they were on the same wire.

Physical segmentation occurs at the network layer and a larger internal network is split into subnetworks. The data flow between the different subnets is limited and controlled through firewall policies, access control lists (ACLs) and routers.

A software defined wide area network (SD-WAN) [allows communication over the internet using encrypted overlay tunnels] is implemented at the application layer. With an SD-WAN, the physical network, also known as an underlay network (refers to the physical network infrastructure), applies an overlay network (refers to the virtualized network built over the underlay network). The overlay network includes tunnel encrypted virtual paths.

One way to securely access segmented networks is to use a jump box. A jump box is a device with enhanced access control, and limited authorization that acts as a proxy to the devices in the internal segment. A jump box also has additional monitoring and logging to alert the IT manager if it has been compromised. Another method of accessing network segments is a bastion host. A bastion host is a server or computer whose purpose is to provide access to a private network from an external network. It is configured to withstand attacks while allowing the users to access subnets through just one application. An example of this is a secured HTML connection. The bastion host provides secure SSH and RDP connects to the internal network segment.

Benefits of Network Segmentation:

- Easier network management configuration
- A reduction in the number of network broadcasts
- The minimization of network congestion
- A limiting of attacks to a pacific segment
- Greater protection of vulnerable devices
- A reduction of the scope of devices affected by compliance

The Evolution of Firewalls

As networks began to grow, interconnect with one another, and eventually connect to the internet, it became important to control the flow of network traffic. Firewalls became a means of control that had to evolve and change alongside networks. They are classified into generations defined as first-generation packet filter/stateless firewall, second-generation stateful firewall, third-generation firewall, and next-generation firewall (NGFW).

How Firewalls Work:

- **First-Generation Firewall:** a packet filter/stateless firewall, examines the routing and transport layer protocols information such as source and destination network addresses, protocols and port numbers. Firewall policies use these attributes to define which packets are allowed through. The rules are ordered in a list and the potential match is performed in order from top to bottom. The last firewall policy can be implicit (a policy applied if no other match is found in the firewall policy list), denying the packet by default, or explicit (a policy created to specify if the traffic is allowed or denied), performing the corresponding configured action, or either allowing or denying the packet. A stateless firewall allows a packet to pass if the network addresses, protocol, and port number match those of its firewall policy. If it does not, the packet is either silently dropped, or blocked.
 - A drawback of a stateless firewall is that it requires additional configuration to offer suitable levels of protection. For example, it requires an additional firewall policy for return traffic in a session.
 - It also fails to appropriately manage protocols. Stateless firewalls open random ports and use multiple connections, like FTP, with its control and data connections.
 - Stateless firewalls use a “one-size-fits-all” approach to decide whether to allow traffic to pass. Because of this open approach, bad actors can potentially bypass firewall rules and inject rogue packets through acceptable protocols and ports, or exploit bugs in a computer networking software.
- **Second-Generation Firewall:** known as a stateful firewall, offsets the limitations of the stateless firewall by developing additional criteria for blocking or allowing traffic. A stateful firewall is designed to observe the network connections over time by tracking the 5-tuple check and the connection state in its session table. It watches as new network connections are made, and continuously examines the traffic going back and forth between the endpoints. If a connection behaves improperly or if the return traffic does not match the corresponding incoming traffic, the firewall blocks that connection. Any packet that does not belong to a known conversation or does not match an allowed firewall policy is dropped.
 - Cannot block rogue packets if they are using an acceptable protocol, such as HTTP. The explosion of the World Wide Web promoted HTTP as one of the most frequently used network

protocols. The problem is that HTTP is used in many ways, such as in static text content, e-commerce, file hosting, and many other types of web applications. Because they all use the same port number (80), the firewall is not able to distinguish between them. Network administrators need to distinguish between approved and malicious applications to determine which ones to pass or block. Firewalls must look deeper into the data payloads to determine how protocols such as HTTP are used.

- Third-Generation Firewall: looks deeper into the data payloads, while still stateful, these firewalls understand the application layer protocols and control different uses of the same basic protocol. This is known as application layer filtering. Firewalls that implement application layer filtering can understand protocols such as HTTP, FTP, and DNS. HTTP can distinguish between browser traffic, a blog, a file sharing site, e-commerce, social media, voice-over-IP, and email. UTM firewalls also combine additional protections like antivirus, antispam, an intrusion prevention system (IPS) and a virtual private network (VPN).
- Next-Generation Firewall (NGFW): has multiple security checkpoints/lines of defense.
 - First line of defense: checks packets and uses rule-based decisions to determine whether to allow or drop traffic.
 - Second line of defense: NGFW performs deep packet inspection (DPI), which is the checking for malicious code and network usage. DPIs also ensure that the data format is correct. Depending on the inspection, actions can be alerting, blocking, re-routing, or logging.
 - Third line of defense: NGFW sends malicious content to a sandbox for further screening. A sandbox runs programs in a confined system, and separate from the network. The isolation from the network prevents the spread of malware or other malevolent actions.
 - Evolution of NGFWs:
 - Controls applications by classification or users, which helps protect web-browsing clients from attacks and threats
 - Adopts various segmentation approaches, which segregates users, devices, and applications that are aligned to business needs, which eliminates a single point of entry
 - Has moved from reactive to proactive, where artificial intelligence is used to enforce security policies

- Deliver high performance and greater network visibility, with little to no degradation, to support and protect modern, distributed data centers located within a complex and hybrid IT infrastructure. Hybrid data centres offer businesses greater agility, flexibility, and scale on demand, as well as an expected attack surface that requires an equally evolved security strategy. High performance inspection includes applications, compute resources, analytics, encrypted data that moves throughout the infrastructure, and data storage across multiple private and public clouds.

A firewall must prevent evolving cyberattacks at every edge of the network, while delivering security, reliability, and network performance.

The Importance of Secure Switching and Ports

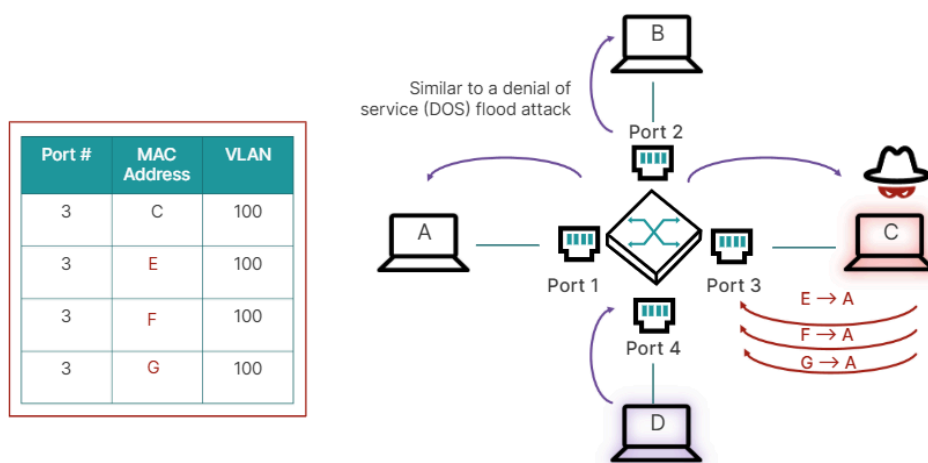
Switches operate at the data link layer of the OSI model. They assign packets to VLANs based on the source MAC address of the packet frame. Switches store port information, including port capabilities, VLAN parameters, and the MAC addresses of devices connected to the switch in a content-addressable memory, or CAM table. Switches send frames to the ports of the corresponding switch. Without secure switching, switches can be vulnerable to any attacks at the data link layer.

Common Threats and Attacks

While the CAM table allows for faster packet forwarding and fewer collisions, by default switches are prone to potential storms. Storms can flood a frame when it is a broadcast frame (a frame that has all the bytes on the destination MAC address set to FF), unicast frame (a frame that has an unknown destination MAC address is not known by the CAM table), or multi-cast frame (has an unknown multicast MAC, meaning that it is not configured in the CAM table), and the MAC address is not in the CAM table. To avoid a potential excessive flood, switches can control the maximum number of broadcast, unknown unicast, and multi-cast packets sent per second on a port through a configurable threshold.

An attacker can exploit the way a flood attack works to create a MAC flooding attack (an attack with the objective to fill up the switch's CAM table, creating potential denial of service and sensitive information leakage). Consider the example of a switch with one VLAN, four ports, and one entry in its CAM table related to the device C with its MAC address C connected to port 3. Device C is compromised and starts sending

frames with the MAC spoofing attack, which means that the frames are sourced from fake MAC addresses. This scenario shows this as E, F, and G. The switch receives these frames on port 3 and updates its CAM table with the corresponding fake MAC addresses. Once the switch CAM table is full, it is unable to learn additional MAC addresses and port mappings. Therefore when device A sends a frame on port 1, its port mapping is not added to the CAM table, because it is full of fake MAC addresses. The subsequent frame from device D to MAC address A is then not forwarded to port 1, but flooded to all the ports. The result is similar to a denial of service (DoS) attack with the legitimate traffic disrupted by this flood. A second effect is that the compromised device C also receives sensitive information from all other devices here from device D.



You can contain a MAC flooding attack by limiting the number of entries per port or VLAN. In the previous example, you could avoid attacks by limiting the number of entries per port to 1. Therefore even if device C is compromised, the subsequent frames with the spoofed MAC addresses do not create additional entries in the CAM table and the frames are dropped. When device A sends a frame, its MAC address A is added to the CAM table, allowing device D to get its frame directly forwarded to device A without flooding all the ports. In this example, the switch dynamically adds the MAC address entries for MAC addresses A and D. These dynamic addresses are deleted automatically from the table after their expiry time. To enable stricter policies, you can enter MAC addresses statically (the MAC address is configured and never removed from the switch's CAM table), therefore with the previous limit of one entry per port, the switch can completely block the MAC spoofing and flooding attacks on a port. Since a static table may provide some constraints you can also configure switches with sticky MAC addresses (the switch learns the MAC address, which becomes a persistent entry in the switch's CAM table. It is only removed when the switch reboots). In this case, the MAC address is learned on the port and its entry is not deleted, unless the switch is rebooted. Creating a stick MAC address removes the constraint of entering the static

MAC address in the table. 802.1X Authentication (a standard that is designed to provide authentication to network devices that want to join a network) is another form of security that you can add to ensure secure switching. In this situation, the device must be authenticated before it can access the switch.

Secure Switching and Ports Best Practices

The best practices to secure switching and ports are:

- Protect physical switches locally. For example, in a closet or restricted room. Switches are vulnerable LAN elements, and you must place them in a secure location. You must also restrict managing access with authentication, authorization, and a secure protocol, like SSH or HTTPS.
- Separate switches to enforce better physical segmentation. In particular, you should separate switches between internal and external networks so you can prevent them from being compromised at the same time.
- To limit a MAC flooding attack, restrict the number of MAC addresses allowed on a specific port
- Configure sticky or static MAC addresses. This could reduce MAC spoofing. It also provides additional security by keeping a list of static MAC address list up-to-date in a dynamic environment
- Use access control lists of verified MAC addresses to filter unverified addresses, and prevent MAC flooding attacks
- Add port authentication, such as IEEE 802.1x standard
- Implement port mirroring to actively monitor port activity

What are Security Protocols?

A protocol provides a set of rules and methods used to establish a communication between different devices.

Previously in a network environment, protocols were initially defined in clear text; for example, emails used multipurpose Internet mail extensions (MIME) [a standard that extends protocols like the simple mail transfer protocol (SMTP) to handle non-ASCII data], web browsing used HTTP, remote control used Telnet, and remote access used L2TP. However as security became a mandatory requirement, former protocols evolved. In the previous examples, security was added to email through secure MIME (S/MIME), to web browsing through HTTPS, to remote control through SSH, and to remote access through IPsec.

How Protocols are Secure

- For S/MIME, first the email is signed with the sender digital signature before being encrypted with the receiver public key. After the email is sent the receiver decrypts the email with their private key, and the digital signature confirms the identity of the sender. Therefore security is added through the digital signature, which provides authentication, non-repudiation, and data integrity. End-to-end encryption provides confidentiality.
- In the case of HTTPS, the security is provided by transport layer security (TLS) [encrypts the data sent over unsecured networks, like the internet. it supersedes secure sockets layer (SSL) standard, and the current latest recommended version is 1.3.]. As the client initiates the connection, the server answers providing their public key. The client generates a random session key and encrypts it with the server public key, before sending it to the server. The server decrypts the session key with its private key. The web traffic is then encrypted through this symmetric key, which uses less resources than asymmetric encryption. Because it does not include authentication between the client and the server, this communication is subject to the man-in-the-middle mechanism (MITM) [allows a device to intercept communication between the user and the application. The communication is then no more direct, but relayed by the intermediate device.], where an intermediate device intercepts the initial HTTPS connection over the default port 443 and creates two sessions.
- The same authentication is included in the SSH protocol because it performs a verification of the end-to-end connection. The client's public key is already stored in the SSH server. Therefore, when the SSH server receives a connection request from the client, it sends back a random message encrypted with the SSH client's public key. The client receives this encrypted message and decrypts it with its corresponding private key. The client sends back the message to the SSH server. If the message corresponds to the initial message, the client is authenticated. Further communication encryption is implemented through the Diffie-Hellman (DH) [allows to secretly share a symmetric key through a communication using asymmetric keys (the private key is kept locally while the public key is shared)] key exchange. This communication also includes integrity with a message authentication code (MAC) [creates a hash that is attached to a message to ensure its integrity and authenticity] algorithm, available in SSH protocol version 2. SSH protocol is commonly used for file transfer like secure copy protocol (SCP), tunneling, and network management over the default port 22.

What is a Sandbox?

A sandbox, in the context of computer security, is a system that confines the actions of an application, such as opening a Word document or browser, within a safe virtual environment. In a sandbox, an application is isolated so that any malicious intent can be uncovered safely without causing harm to the network. If something unexpected or dangerous happens, it affects only the sandbox, and not the other computers and devices on the network. Sandbox technology is typically managed by an organization's information security team, but used by network, applications, and desktop operations teams, to bolster security in their respective domains.

Why was Sandbox Technology Created?

Threat actors exploit vulnerabilities in legitimate applications in order to compromise a device, and from there move through the network to infect other devices. Firewalls and antivirus software can stop known threats, but they are helpless against zero day-attacks. A zero-day attack is when a threat actor exploits an unknown vulnerability. Sandboxing was created as a defense against zero-day attacks.

How Does Sandboxing Work?

A sandbox offers an isolated virtual space that mimics computer systems and applications. It allows potential threats to run safely within these virtual systems and analyzes these threats. If a sandbox deems that a file is safe, it does not take any action; but if it detects malicious behavior, it quarantines the file and prevents it from accessing other computers and devices on the network.

How Has Sandbox Technology Evolved?

The evolution of sandboxing solutions can be broadly categorized into three generations, starting from their rudimentary beginnings and progressing to advanced and sophisticated solutions available today:

- First Generation: Early sandboxes encountered challenges when trying to share threat intelligence with other security devices due to security architecture dependence on standalone solutions. Standalone solutions could not easily integrate with products from other vendors forcing the security operation center (SOC) to use a separate management console for each one. Consequently, the process of consolidating and analyzing threat intelligence data was both challenging and time consuming.
- Second Generation: Second-generation sandboxes were better at integrating with other security devices, allowing for improved intelligence sharing. This new approach to network security allowed analysts to correlate threat intelligence centrally and respond to threats from a single pane of glass. Moreover, an integrated network security environment

could share information with a threat intelligence service in the cloud, which could then push that intelligence to other networks.

- Third Generation: Threat actors are leveraging automation and artificial intelligence (AI) methods to accelerate the development of new security exploits. AI-driven attacks necessitated a third-generation sandbox based on a threat analysis standard. The third generation of sandbox devices not only help detect breaches in a timely manner, they also prevent them from happening. These solutions utilize the universal MITRE ATT&CK security language (provides security devices with a common language in which to identify, describe, and categorize threats, which can be shared with and readily understood by other vendor devices) for categorizing threat models, and methodologies.

Common Network Threats

Network threats are unlawful or malicious activities that intend to take advantage of network vulnerabilities. The goal is to breach, harm, or sabotage the information or data valuable of a company. Malicious actors also attack networks to gain unauthorized access and manipulate the same according to their intentions. The motivations can be political, financial, or retaliatory. Common threats include:

- Spoofing: Spoofing is a threat during which the attacker impersonates an authorized device or user to steal data, spread malware, or bypass access control systems. The attacker is capable of spoofing any unique user or system identifier like a MAC or IP address.
- Hijacking: During a hijacking threat, an attacker intercepts a connection to discover, and potentially modify the initial two parties' communications. Man-in-the-middle is an example of a hijacking attack. To prevent it, an end-to-end encryption with multifactor authentication provides confidentiality and validates the initial two parties.
- Replay Attacks: While an attacker performs a hijacking attack in real time, a replay attack is delayed. It intercepts a communication and maliciously repeats or resends the data later. For example, by fraudulently replaying an authentication, an attacker could access confidential applications. A one-time session token can prevent replay attacks.
- Transitive Attacks: A transitive attack uses the trust chain between devices. If device A trusts device B, and device B trusts device C, device A could then trust Device C. If one device is corrupted, the other could also be attacked. You can prevent this transitive attack by implementing the zero-trust concept.

- Denial of Service (DoS): During a denial-of-service (DoS) threat, the attacker attempts to exhaust the network resources and block legitimate resource requests. An example of a DoS attack is when an attacker attempts to exhaust the network resources by using botnets. If the attack is successful, resources become unavailable and legitimate users are denied access. Examples of DoS attacks include:
 - Flood attacks: The goal of flood attacks is to overwhelm a device. Usually, a botnet creates the attack with connectionless traffic like UDP or ICMP.
 - Smurf attack: In a smurf attack, the attacker spoofs a victim's source IP to broadcast an Internet Control Message Protocol (ICMP) packet to a network. After the attacker sends the packets, most of the devices in the network reply to the original source IP address, flooding the victim's device with traffic and reducing its resources for legitimate requests.
 - Fraggle attack: Similar to a smurf attack, a fraggle attack spoofs a victim, and sends a spoofed UDP packet to the router's broadcast address. The victim's device is then flooded with traffic, reducing its resources for legitimate requests.
 - SYN flood: A SYN flood is part of protocol attacks specifically targeting servers, proxies, or firewalls. During this attack, the attacker creates an incomplete TCP three-way handshake, allowing SYN floods to exhaust the resources of the device, which is waiting for half-opened connections.
 - Christmas tree attack: During a Christmas tree attack, the attacker sends out multiple TCP packets with the FIN, URG, and PSH flags set. These Christmas tree packets require more processing by routers and hosts, reducing their resources and potentially making them crash or reboot. A protocol analyzer identifies and analyzes these packets.
 - Ping of death: While a ping is typically less than 100 bytes, a ping of death creates packets greater than 65,535 bytes. During a ping of death, the origin device fragments the packets before the transmission. When the target device reassembles the malformed packets, a buffer overflow or a crash can occur.
 - Teardrop attacks: A teardrop attack involves sending fragmented packets, modified with overlapping and oversized payloads. When

the target device tries to reassemble the fragments, the packets overlap one another, crashing the target network device.

- Permanent DoS: In a permanent denial-of-service (PDoS), the attacker exploits vulnerabilities of the device to replace its software by a corrupted firmware image, rendering the device useless. A reboot of the device is not enough, instead the recovery of the device requires a reinstallation of the correct firmware or a total hardware replacement.
- Fork bomb: A fork is a system call used in Unix and Linux systems that replicates an existing process. Because a fork loop consumes CPU and memory, a kernel panic can occur on the device, blocking the system completely. A fork bomb continues to replicate itself through the child processes, depleting available resources, and slowing down or crashing the system.

Prevention of DoS Attacks

To prevent DoS threats, network devices, like firewalls, can implement anomaly checks of the packets. This mechanism can block ping of death, Christmas tree and teardrop attacks. You can prevent fork bombs by limiting the number of processes a user can own. To prevent smurf and fraggle attacks, routers no longer forward packets directed at their broadcast addresses. Also to limit floods in general, firewall mechanisms, like DoS sensors or network behavior analyzers using artificial intelligence keep the traffic under expected amounts.

Additional Best Practices

In addition to the previous prevention methods, two important best practices are to close unnecessary ports, and fix known vulnerabilities. Neglecting these steps can provide points of entry for network threats, like leaving doors and windows open at home. To find open ports, a port scan, like Nmap can provide a comprehensive list. If the unnecessary ports cannot be closed directly on the server, you can create a firewall policy that blocks access to these specific ports on the front firewall. You can identify vulnerabilities with a penetration test. The best practice is to update the network devices regularly with the latest patches. Like network segmentation, or the implementation of zero-trust principles, these practices are part of the hardening measures.

What is Operational Technology?

Operational Technology (OT) refers to hardware and software that monitor and control physical devices, processes, and infrastructure.

Why Does OT Security Matter?

Because OT systems control physical infrastructure, a cyber attack can cause operational disruptions, environmental damage, or even pose a risk to public safety. OT security protects operational systems from cyberthreats to ensure safe, reliable, and continuous operation of physical processes.

What is the difference between IT and OT?

To fully understand OT security, we need to understand how OT-operational technology differs from IT-information technology. On the surface both involve computers and networks, but their goals, environments, and priorities are fundamentally different. IT systems are designed to manage information processing, storing, and transmitting data. OT systems control physical processes, run machines, and manage infrastructure. While IT environments prioritize data confidentiality, and integrity, OT environments emphasize the reliability, availability, stability, and safety of physical operations. IT supports business systems and communications, and OT requires real time traffic without delays. These differences aren't just technical, they determine how we approach security for each environment.

How is IT-OT convergence affecting the OT Security landscape?

OT security is becoming increasingly important as IT-OT convergence reshapes industrial environments. Historically OT systems operated in isolation separated from IT networks and the Internet. This air gap acted as a natural security barrier, limiting remote exposure. Today that model is changing. IT-OT convergence integrates operational systems with enterprise IT to enable real-time visibility, remote access, and improved efficiency. However, connecting a previously air-gapped OT network to the Internet through an IT network, immediately exposes the OT environment, and all connected devices to the broader threat landscape. As connectivity expands, so does the attack surface. For this reason, dedicated OT security measures are essential to protect operational integrity, safety, and reliability.

What are the Common Components of OT?

To effectively secure OT environments, it is important to understand their foundational components. These are specialized systems designed to monitor, control, and automate physical processes.

- Industrial Control Systems (ICS) are a subset of OT used to monitor and control industrial processes. They include DCS, PLC, and SCADA systems, which automate operations and provide precise control over equipment and production processes.

- DCS are systems used to control large complex industrial processes, such as oil refining, or chemical manufacturing, where multiple control loops operate simultaneously.
- PLCs are ruggedized industrial computers that automate and control machinery, and processes, on the factory floor. They execute pre-programmed logic based on real-time sensor input
- Supervisory control and data acquisition (SCADA) systems provide centralized control, and monitoring of industrial processes across large geographic areas, such as pipelines, power grids, and water systems.
- The Industrial Internet of Things (IIoT) refers to interconnected devices and sensors deployed in industrial environments to enable advanced data collection, analysis, and automation. IIoT bridges, traditional OT systems with modern IT capabilities, supporting real time monitoring and predictive maintenance.
- Human-machine interfaces (HMI) are operator dashboards that display real-time system data, and allow control of industrial processes.
- Remote Terminal Units (RTUs) are field devices that collect data from physical equipment and send it to central SCADA systems, often in remote or distributed locations.

What are the Common OT Security Threats?

OT environments face unique security threats with operational consequences. Some of the main types of threats include the following:

- **Malware:** Malicious software designed to disrupt, damage, or gain unauthorized access to OT systems. In industrial environments, malware can interfere with control processes, compromise system integrity, or enable further intrusion.
- **Unauthorized Remote Access:** As IT and OT systems become more interconnected, poorly secured remote access pathways can provide attackers with entry into industrial control systems.
- **Targeted Supply Chain Attacks:** Threat actors compromise trusted third-party vendors or software providers to infiltrate OT environments. Because industrial systems often depend on specialized, external tools and updates this attack vector presents increasing risk.
- **Insider Threats:** Risks arising from malicious or negligent actions by employees, contractors or vendors with legitimate access to OT systems. Insider threats are particularly serious because authorized access can bypass perimeter controls.
- **Nation-State Actors & Advanced Persistent Threats (APTs):** State-sponsored groups targeting critical infrastructure; such as energy, water, or defense sectors to conduct espionage, disruption, or sabotage.

- Ransomware: A specific type of malware that encrypts systems or restricts access until payment is demanded. In OT environments ransomware can halt production, disrupt critical services, and impact operational continuity.

Why is OT Security uniquely difficult?

OT security faces unique challenges because many systems are legacy technologies that cannot easily support modern security tools. At the same time, industrial operations often require zero downtime, making it difficult to apply patches or updates without disrupting production. OT environments also tend to have limited visibility into network activity, and many industrial protocols lack built-in security features such as encryption. In addition, traditional OT networks often lack segmentation, making it easier for threats to move once inside. Together these factors make securing OT systems complex, and operationally sensitive.

What are the Benefits of Ensuring Strong OT Security?

A strong OT security posture delivers benefits that extend well beyond preventing cyber attacks. Here are some of the key benefits of a secure OT:

- OT security ensures that industrial processes continue to run without interruption. Any unplanned downtime whether caused by a cyber attack or system failure can have cascading consequences for services, supply chains, and communities.
- Ongoing monitoring of OT network activity enables organizations to detect both known and emerging threats. By identifying connected devices, profiling traffic, and defining the attack surface, security teams gain the visibility needed to manage systems, protocols, and services effectively.
- OT security ensures that systems perform their only intended functions. Measures such as multifactor authentication, network segmentation, microsegmentation, and sandboxing, restrict unauthorized access and contain potential threats before they spread.
- Many OT devices, such as power grids, and medical devices are subject to strict operational security requirements. Strong OT security practices help organizations meet regulatory obligations, and avoid penalties, shutdowns, or reputational damage.
- Protecting OT systems reduces the likelihood of incidents that could endanger employees, communities, or critical infrastructure. Preventing equipment malfunction, or unsafe conditions remains one of the most important outcomes of effective OT security.

What are the OT Security Best Practices?

Effective OT security requires structured, layered controls that protect systems across all levels of the environment. The following are some best practices that support a strong OT security posture:

- A strong OT cybersecurity program begins with clearly defined governance, including established roles, policies, and a risk management framework aligned to industrial environments.
- Network segmentation forms the foundation of technical protection by separating OT from IT using firewalls and unidirectional gateways for

access control. Least privilege access, multifactor authentication and secure remote connectivity, reduce unnecessary exposure. Structured asset management, and carefully planned patching further strength system integrity.

- Continuous monitoring, and anomaly detection provide real-time visibility into OT networks, enabling early identification of abnormal behavior.
- Comprehensive incident response planning, regularly tested and supported by recovery and restoration capabilities, ensures resilience during disruption.
- Ongoing security awareness training reinforces secure practices, and reduces human-related risk.

Module 7: Authentication and Access Control

How can you prove your identity?

- Inherence: uses a unique physical trait that the person authenticating possesses:
 - Finger print
 - Retina
 - Iris
 - Facial pattern
 - Hand measurement
- Possession: authentication using something you have, that no one else has:
 - Bank card
 - Private signing key
 - Machine or device
 - Hardware and software token: a hardware token is a dedicated device that generates an OTP using a secret key and algorithm. Because the authenticator shares the same secret key and uses the same algorithm as the token, it generates the same one-time code.
 - SMS messaging
- Knowledge: you authenticate by divulging something that only you and the authenticator know:
 - Question & Answer (Q&A)
 - Password
 - Personal identification number (PIN)
- Behavior: uses active biometric data to identify a person:
 - Voice identification
 - Keystroke dynamics
 - Mouse use characteristics

Single-factor Authentication: the system prompts you for a single form to prove your identity, such as a username and password.

Multi-factor Authentication (MFA): two or more forms of authentication, not as likely that bad actors have compromised multiple authentication factors, MFA coupled with other network security techniques is a powerful instrument to defend your network.

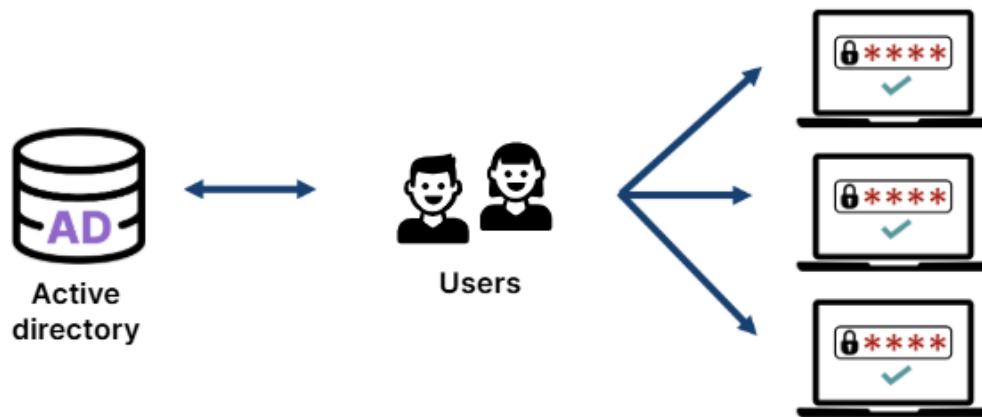
What is Single Sign-On (SSO)?

True SSO is an authentication process whereby a user authenticates once and can access multiple resources across many systems and possibly domains. Instead of having to authenticate on each system before accessing the resources on those systems, one authentication suffices. This is achieved when the system, from which the user has already authenticated, passes an authentication token seamlessly to other applications or sites. An authentication token could be a cookie, but only if the sites share a common parent domain.



What is Same Sign-On?

In same sign-on, an entity uses their credentials housed in a directory server to access applications. Typically, lightweight directory access protocol (LDAP)-compliant directory servers are used for these purposes. Although the entity uses the same credentials stored in the LDAP directory, they still would have to authenticate to each application/



Implementing SSO is common in enterprises where a user accesses multiple resources across the network. But SSO is also prevalent in the cloud traversing multiple domains and separate autonomous networks. If you have ever registered on a site, such as Spotify, you may have been given the option of leveraging existing user credentials on a different site. In the example of Spotify, the choices are Facebook, Apple, and Google. Thus, if you already have credentials on any one of these sites, you can use those to authenticate on Spotify. This arrangement is only possible because of trust existing between Spotify, which is the Service Provider (SP), and the other three businesses, which are the Identity Providers (IdP).

Advantages and Disadvantages of SSO

Advantages:

- Reduces the burden of having to remember multiple credentials for the end user
- Reduces credential redundancy and administrative overhead for the organization
- Facilitates compliance and user reporting

Disadvantages:

- Compromised credentials give the bad actor access to everything, however, MFA can be implemented by the user to strengthen authentication, productivity, and ease-of-access.

How Does SSO Work?

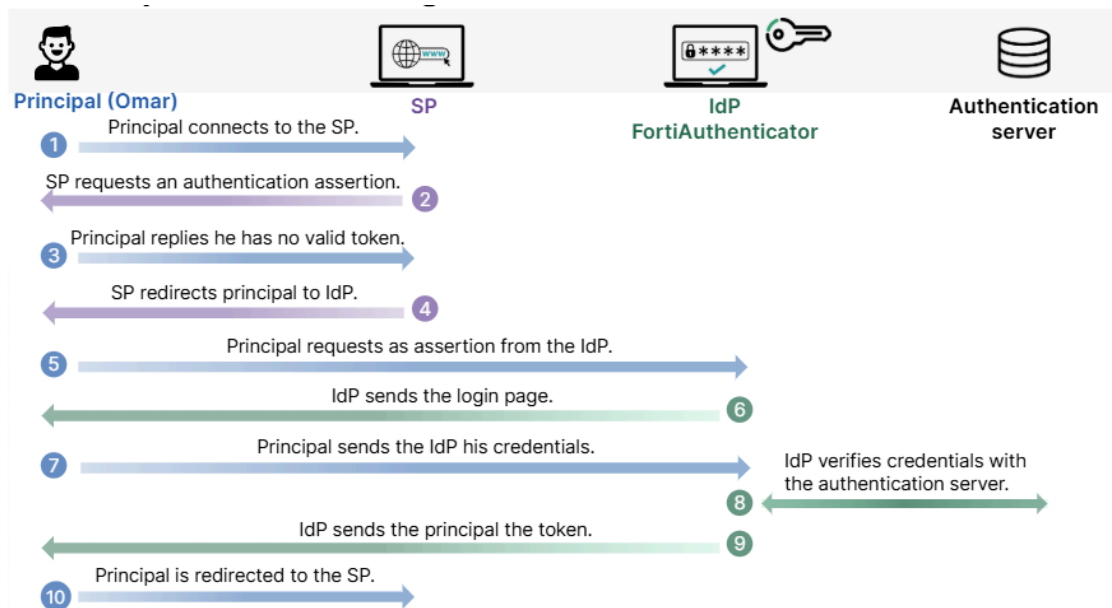
1. The user connects to an SP, such as a website or application
2. The SP redirects the user to the IdP to log in
3. The user provides their credentials and authenticates on the IdP
4. The IdP generates an authentication token. The user is sent back to the original site, and the embedded token acts as proof that they have been authenticated



SSO Protocols for Implementation:

- OAuth
- Security Assertion Markup Language (SAML)
 - Open standard for exchanging authentication data between parties, in particular, between the IdP and SP.
 - Based on the Extensible Markup Language (XML)
 - Inserts statements within the XML-based messages
 - Uses security assertions to exchange information between parties:
 - **Authentication** assertion indicates how the entity authenticated and includes the date and time of authentication
 - **Attribute** assertion provides additional information about the entity
 - **Authorization** assertion identifies what the entity is entitled to do

SSO protocols are open standards for access delegation, commonly used as a way for internet users to grant websites or applications access to their information on other websites but without giving them the passwords.



What is an Authentication Framework?

The basic schema or plan for how entities will prove their identities within a system. It includes the methods, forms, protocols, and other tools used to authenticate persons, devices, and applications to a network:

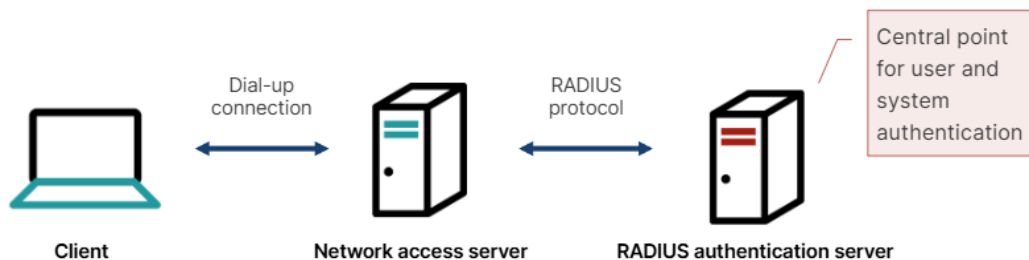
- Method: authentication methods or factors are the main means by which an entity will prove their identity. These means could be based on knowledge, possession, inherence, or behavior.
- Form: authentication forms are the mechanisms by which the entity will prove their identity. For example, under the knowledge factor, there are password, PIN, and question and answer forms.
- Protocol: authentication protocols are computer communication standards used to authenticate an entity to an authenticator. Specifically, a protocol defines the transfer of authentication data between two entities and includes the type of syntax used and the sequence of events.
- Tool: tools are the software and hardware used for authentication. For example, an API can leverage the OAuth 2.0 authorization framework to orchestrate approvals automatically between the API owner and the service. In this instance, OAuth is the software tool. Another example of a software tool could be a software token installed on a device. Likewise, a hardware tool could be a hardware token or biometric device.

Authentication Protocols

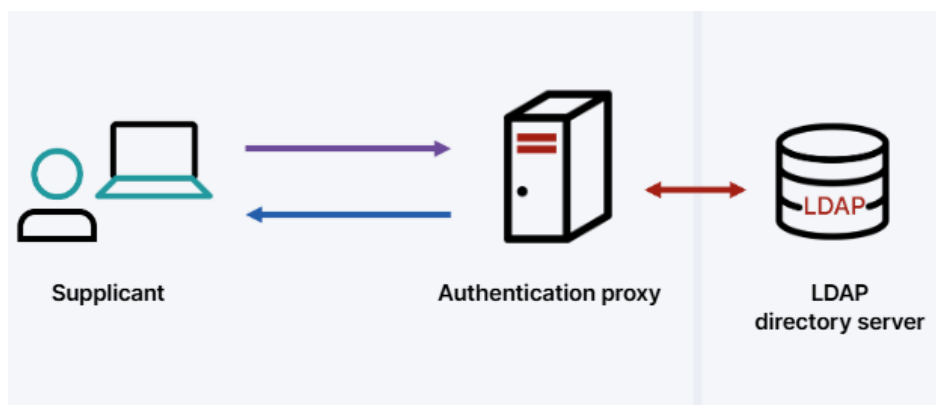
- Remote authentication dial-in user service (RADIUS)
 - A client-server authentication, authorization, and accounting (AAA) protocol and software that enables remote access servers to communicate with a central server to authenticate dial-in users and authorize their access to the requested system or service. The important word here is “central”, because it means that most or all of a network’s remote authentication requirements can be met with one server as opposed to having to maintain multiple credentials across numerous servers. This simplifies administration for both the administrator and the end user.
 - Can enable the 802.1x framework, which uniquely encrypts user sessions
 - RADIUS Authentication Process: Data packets are used to exchange data between computing devices in a packet-switched network. They are formatted units of data consisting of control information and user data, also known as a payload. During RADIUS authentication, the user submits a request to access a server or network along with their credentials. The RADIUS client, which could be a firewall, forwards the Access-Request packet to the RADIUS authentication server. The RADIUS server replies with one of three possible packets. One possibility is that the server returns an Access-Reject packet because the credentials were incorrect. The second possibility is that the server replies with an Access-Accept packet. The last possibility is that the server sends

to the RADIUS client an Access-Challenge packet. This last option only occurs if two-factor authentication has been configured, and it would prompt the user for their second credentials.

- RADIUS User Credentials Repository:
 - RADIUS database
 - External servers:
 - Structured query language (SQL)
 - Lightweight directory access protocol (LDAP)
[Microsoft Active Directory (AD) is an example of an LDAP-compliant directory]



- Lightweight Directory Access Protocol (LDAP)-Compliant Directory
 - An open, vendor-neutral, industry-standard application protocol for accessing directory services over an IP network
 - An industry-standard communication protocol for directory servers
 - In this scenario, the supplicant interfaces with an authentication proxy, which could be a firewall. The proxy queries the LDAP server for the user's credentials and privileges.



- TACACS+
 - Similar to RADIUS, TACACS+ is a remote authentication, authorization, and accounting (AAA) protocol
 - Allows a remote server to communicate with an authentication server in order to validate user access
 - Differences:

- TACACS+ encrypts all AAA protocols while RADIUS encrypts passwords only
- TACACS+ relies on TCP as a network transport protocol while RADIUS uses UDP

Authentication Methods: define the manner in which authentication takes place. They could also be described as protocols that set the rules for interaction and verification, which endpoints of systems use to communicate.

Password authentication protocol (PAP): used to authenticate PPP sessions. The point-to-point protocol (PPP) refers to a suite of computer communication protocols that provide a standard way to transport multiprotocol data over point-to-point links. PPP provides services at layer two- the data link layer of the OSI model- that establishes a foundation upon which network layer protocols can operate. PAP uses a two-way handshake process to authenticate a client using these steps:

1. The client sends the username and password to the server. It does this through an Authentication-Request packet
2. The server verifies the username and password. If the credentials are correct, then the server sends an Authentication-Ack Response packet to the client, and a PPP session is established between the client and the server.

While the information can pass through an encrypted tunnel to enhance security, the static username and password information is subject to numerous attacks through password guessing and snooping

Challenge handshake authentication protocol (CHAP): also used to authenticate PPP sessions, but uses a three-way handshake. It creates a unique challenge phrase for each authentication session by generating a random string. The random string is combined with a hash result of the device hostnames. This ensures dynamic authentication information for each session and avoids static information.

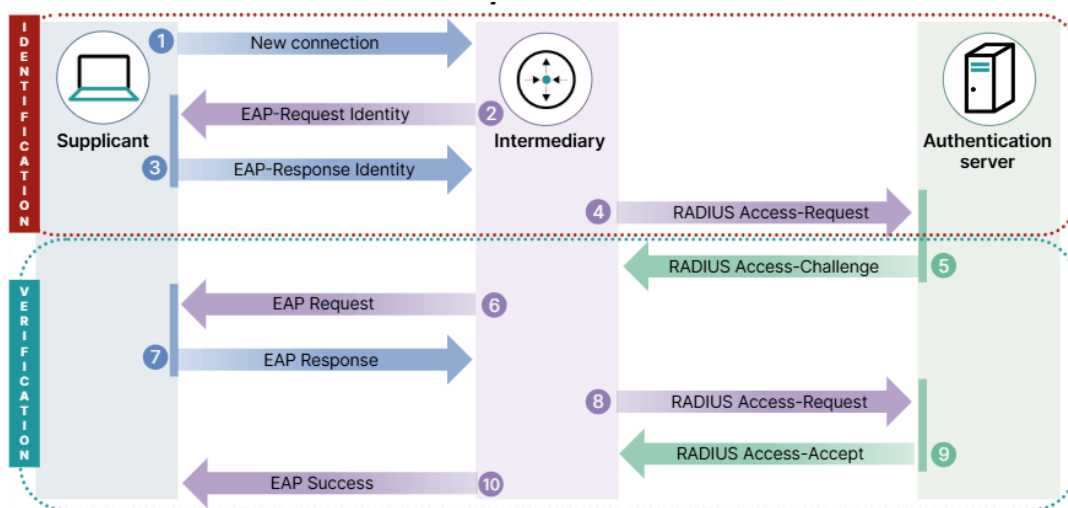
Both PAP and CHAP protocols can be used with VPNs.

802.1x Authentication Framework: an IEEE (The Institute of Electrical and Electronics Engineers is a professional association for electronic and electrical engineering) standard for port-based network access control (PNAC). It provides an authentication mechanism to devices wishing to attach to a LAN or wireless LAN. 802.1x authentication requires three players: a supplicant, an intermediary (also known as an authenticator), and an authentication server. The supplicant is the client device that petitions to join the LAN. The medium can be either ethernet or wireless. The intermediary is a network device that provides a data link or bridge between the client and the network, and can block or allow access to the network depending on the authentication results. The intermediary device could be an ethernet switch or wireless access point. The authentication server is a trusted server that validates the credentials of the supplicant and has the wherewithal to reject or accept the credentials. The

authentication server typically supports RADIUS and EAP protocols. There is a wide range of authentication factors and forms supported, and include knowledge-based username and password and possession-based digital certificate.

The 802.1x Authentication Sequence is as follows:

1. The supplicant makes a connection to the network
2. The intermediary requests the supplicant to identify itself
3. The supplicant provides its identity
4. The intermediary forwards the identity to the authentication server
5. The authentication server returns the challenge to the intermediary
6. The intermediary forwards the challenge to the supplicant
7. The supplicant replies to the challenge
8. The intermediary forwards the information to the authentication server
9. If the credentials are accepted, the authentication server sends an accept message to the intermediary
10. The intermediary sends the accept message to the supplicant and allows the supplicant access



Extensible Authentication Protocol (EAP) Framework: an authentication framework, not a specific authentication mechanism. It provides some common functions and negotiation of authentication methods, called EAP methods. Some EAP methods include:

- EAP-FAST: stands for flexible authentication via secure tunneling, handles authentication by using a protected access credential (PAC) that an authentication server can manage dynamically. A PAC is a security credential generated by the server that holds information specific to a peer, which, in this case, would be the relying party or service provider. The server uses the transport layer security (TLS) protocol to establish a secure communication tunnel to the peer.
- PEAP: stands for protected EAP, a protocol that encapsulates EAP messages within an encrypted and authenticated TLS tunnel. PEAP

authenticates Wi-Fi LAN clients using only server-side certificates, which simplifies the implementation and administration of a secure Wi-Fi LAN.

- LEAP: stands for lightweight EAP, an EAP authentication type used primarily in Cisco Aironet wireless LANs. It encrypts data transmission using dynamically generated WEP keys, and supports mutual authentication between a wireless client and a RADIUS server.

Access Control: also called authorization, determines what you can access, the ability to restrict access to a physical location or resource.

What are Access Control Methods?

An access control method is the system used to determine what resources a user is allowed to access based on authentication and the application of rules.

Common Access Control Methods: Mandatory and Discretionary access controls define whether the object being restricted, or the enforcing agency can change the access control rules. An access control method can be either mandatory, or discretionary, but not both.

- Mandatory Access Control (MAC): does not allow any participating actor to change the security requirements. Mandatory access control forces all users and programs to always check the enforcing engine before being allowed access to resources.
- Discretionary Access Control (DAC): allows some flexibility in who defines access. DAC allows an external factor to change access control restrictions. The subject or enforcement mechanism can adjust permissions and even grant new accesses.
- Lattice-based Access Control (LBAC): grants permissions to locations or materials based on an assigned security level. Users and devices are granted access to everything at their level and below, meaning a basic user would only have access to the lowest level of resources, while an administrator, CEO, or person with top secret clearance would have access to the more restricted materials, and any other materials below their level.
- Rule-set-based Access Control (RSBAC): enforces access usually through an ordered list of rules. Rules are usually evaluated from the top down, and as soon as a match is made, access is allowed or denied based on that rule. If an access request reaches the bottom of the list without matching, it can either fail open and allow the access, or fail close, and deny it.
- Role-based Access Control (RBAC): allows access to resources based on roles that have been defined by administrators, and assigned to users or devices. These roles map to a set of permissions, usually some form of access control list. Access is then granted if the user or device is successfully authenticated and has the appropriate role and permissions

to access the resources requested. One of the major benefits of role-based access control is the flexibility in granting permissions to new users. Administrators simply then assign the appropriate role and the user or device should have access to the necessary resources. A disadvantage to role-based access control is the setup time in defining and setting up meaningful roles that take advantage of the flexibility of a role-based system.

- Attribute-based Access Control (ABAC): considers multiple attributes to determine if access should be allowed. A rule engine collects and evaluates attributes against a policy. The major benefit of ABAC is the ability to dynamically allow and deny access based on multiple factors not based on a static rule list like RBAC. What attributes are available for a policy decision vary wildly depending on the type of access control. Nontraditional attributes like patterns of behavior, geolocation, and current resource loads can be considered using ABAC. ABAC attributes can be time consuming and resource intensive to define, and may be inefficient when a simpler access control method may be more time efficient and secure. Extra expertise is usually required when defining an ABAC policy, to avoid configuration errors and potential security holes.

The Identity and Access Management Life Cycle

As a user or device is provisioned or assigned permissions, it travels through the lifecycle until it is deprovisioned and the cycle starts again.

1. Provisioning: create account for user or device, assign roles or groups
2. Authentication: validate identity of user or device
3. Authorization: determine if a valid user has permissions, audit and accounting of connections
4. Self-service: password change, update account information, request access to denied information, report suspicious activity
5. Deprovisioning: remove permissions, remove access control rules, roles, and groups

A governance system, which is usually a team responsible for reviewing and updating access control methods and policies, reviews and modifies the process.

Because of the highly dynamic nature of authentication and granting access, it is important to have periodic reviews and tests of each stage of the lifecycle. Such reviews ensure that the systems are protected while allowing users and devices to access the information they need securely.

Access Control Challenges

Correctly implementing access control can present many challenges:

- Configuring access control
 - Multiple roles, groups, and policies across multiple departments and devices
 - Complexity of rules

- Inconsistent understanding of access control devices
 - Misconfigured or unused rules hampering correct configuration
- Consistency
 - Flexibility required to create appropriate access control policies
 - Creating multiple consistent access control policies and rules across multiple platforms
- User experience
 - Changing passwords
 - Dealing with expired passwords
 - Granting additional access to required resources easily
- Auditing
 - Create a unified paper trail for authentication and authorization
 - Dealing with geographically dispersed sites and access control locations
 - Consolidating multiple types of access control devices and logging types

Access Control Policies for Users, Files, and Folders

- The cause of most security breaches against physical and cyber-based assets is human error. Having a clear, published security policy prevents users from accidentally violating security rules, and can help people recognize when a security breach is occurring.
- Educating users and providing them with the appropriate tools to manage their security settings can drastically reduce the risks from human error. Having a robust password policy, one that requires long length, special characters, and periodic changes, is one of the most effective and easy-to-implement security measures.
- Having appropriate self-service tools, such as password resetting and request forms for allowing different access control, can reduce support calls, improve security, and help maintain a higher security posture.
- Always be aware how access control and file permissions are assigned to large file systems.
- Apply permissions to a folder and all folders and files under it to ensure maximum protection.
- Avoid changing many small, specific, and separated file and folder permissions to a specific group or user.
- Consolidate files and folders with the same permission sets in one location to ease application of access control policy and prevent privilege creep and complexity.

Administrators and Governance:

- Control the security posture and create access control policies
- Define important escalation, disaster and onboarding/offboarding policies
- Communicate these policies through security plans and policies
- Perform periodic audits of user accounts and access control policies

Duty Separation:

- Always maintain separation between users and administrators with accounts and access control policies
- Separate access control for different departments that have different requirements to allow more granular and secure access control
- Enforce these on the OS level using features like Windows User Access Control (UAC) and Linux superuser privileges
- Separate access control through divisions that make sense, such as department, job level, or geographical location
- Minimize overhead, rule creep, and privilege escalation

Access Control Policy Creation and Recertification:

- Create and document access control policy creation so an administrator can see the big picture
- Periodically (at least yearly) review all access control policies to see if they are relevant, or need to be updated or deleted
- Reevaluate access control policies when major network or infrastructure changes occur, and do not assume existing policies will be able to handle new equipment or situations

User Education:

- Knowledge of company security and access control policies
- Ability to create strong passwords and use change forms
- Ability to identify and report suspicious activity or misconfigured access control policies

User Onboarding, Recertification, Offboarding:

- Clear, easy-to-use onboarding methods to create secure access control profiles
- Periodic recertification to ensure users have correct access control policies assigned
- Comprehensive offboarding policies to remove all user access and remove old accounts

Escalation and Disaster Recovery Plans

- Publicized plans for disaster recovery situations
- Clear and easy-to-use escalation strategies to allow users to report suspicious activity and report misconfigured access policy

Network access control (NAC) is an appliance or virtual machine that controls access to a network. It has complete visibility into the network profiles and categorizes devices automatically. It evaluates and classifies security-policy compliance by user, device, location, operating system, and other criteria that may detect unusual activity. Many NAC solutions have centralized architecture that improves the control of devices across large and multi-site networks.

NAC began as a network authentication and authorization method for devices joining the network, which followed the IEEE 802.1x standards. The authentication method involved three parties: the client device, the authenticator, and the authentication server. The authenticator could be a network switch or wireless access point that demarks the protected network from the unprotected network. The client provides credentials in the form of a username and password, digital certificate, or some other means, to the authenticator, which forwards these credentials to the server. Depending on the outcome of authentication, the authenticator will either block the device, or allow it access to the network.

Captive portal: having to interact with a web page that asks the user to agree to legal terms before granting access to the network.

Emerging NAC Challenges:

- Devices trying to connect to the network are personally owned devices (guest devices, BYOD devices, IoT devices), not assets of an organization. The company's MIS department does not control what runs on these devices.
- IoT devices, which are hardware with sensors, transmit data from one place to another over the internet, expanding the attack surface. Organizations buy IoT-enabled devices from other vendors, and these devices connect back to vendor networks to provide information about product use and maintenance needs. Organizations tolerate this situation because IoT devices save them time and money.

IoT Devices: the variety of devices, the lack of standards, and the inability to secure these devices make them a potential conduit for contagion to enter the network. Many IoT devices lack the CPU cycles or memory to host authentication and security software. They identify themselves using a shared secret or unique serial number, which is inserted during manufacturing. But this authentication scheme is very limited, should the secret become known, there is likely no way to reset it. Without the ability to install security software, there is little visibility into those devices.

Current NAC Capabilities

When MIS introduces NAC into a network, the first thing NAC does is create profiles of all connected devices. NAC then permits access to network resources based on the device profile, which is defined by function. If a device does not have a defined profile or a profile that matches a particular function, they are denied entry. NAC grants individuals access to sensitive information and applications based on their need to know. If a device is compromised, malware can infect only those objects that the device is permitted to connect to. To ensure that the network remains secure, user and device policies are adjusted as people, endpoints and businesses change.

Temporary guest access: NAC enables an organization to manage, and authenticate temporary users and devices through a self-service portal

The Importance of NAC

- Improved security: provides oversight of all devices in use across the organization, meaning it enhances security while authenticating users and devices, the moment they enter the network.
- Cost savings: the automated tracking and protection of devices at scale translates into cost savings for organizations because fewer IT resources are needed.
- Automation: as the number and variety of devices organizations use continue to increase, organizations cannot manually verify users and their endpoints' security policies as they attempt to enter the network. The automation features of NAC offer tremendous efficiency to the process of authenticating users and devices and authorizing access.
- Enhanced IT experiences: seamless access provides a user experience that is frictionless when connecting to the network.
- Ease of control: the visibility features of NAC effectively serve as a 24/7 inventory of all the endpoints authorized by the organization. This is helpful not only when IT needs to determine which endpoints or users have been granted access to the network, but also for life-cycle management, when devices must be phased out or replaced.

Module 8: Endpoint Security

Internet of Things (IoT): the network of physical objects connected to the internet by using software, sensors, and other technologies.



Individuals can take precautions by:

- Patching smart home devices.
- Changing default passwords.
- Limiting what data is shared on the internet.



Cities can take precautions by:

- Securing and validating endpoint connections at the enterprise level.



Managers have greater visibility into industrial systems thanks to real-time tracking and asset management.



ICS systems can monitor and adjust parameters on an assembly line, and maximize efficiency and power usage.



Extensive real-time monitoring greatly improves safety and maintenance.

Company strategies



Learn and profile all endpoints, including IoT devices.



Divide the devices into groups by security and connection needs.



Companies should place only devices that need to talk to each other on the same network infrastructure.

Endpoint Hardening Techniques

There are many strategies and policies that one can use to secure traditional and newer network connected devices. Hardening endpoints can be broken down into several categories:

- Using administrative controls to enforce secure passwords, and two-factor authentication, restrict IP addresses using another device such as a router or firewall, and restrict user and network access using the principle of least privilege (PoLP).
- Hardening the local endpoint protection through a combination of operating system security by physically securing devices and locking down BIOS and other boot time systems, boot management, local disk encryption, and data loss prevention (DLP) techniques.

- Appropriate endpoint maintenance to ensure all devices are patched and updated regularly, have regular policy checkups and have accurate, maintained backups for easy recovery.
- Monitoring of endpoint devices, which can be done locally through an endpoint protection platform (EPP) client, if available, or over the networks the devices are connected to using specialized network intrusion detection systems (IDS). It is also possible to implement endpoint detection and response (EDR) platforms that can preemptively block new, undiscovered attacks, and take immediate action against suspicious files and programs.

Firmware

- Software run from a chip on the endpoint
- Responsible for reporting hardware connected to device
- Assists in loading the operating system
- Understanding how network endpoints load their operating systems is important for preventing firmware malware attacks.
- Restricting firmware so that it loads only approved software is one of the most important new features of UEFI (Unified Extensible firmware interface) over BIOS (Basic input output system).

Operating System and Startup

- Select and use an OS that is easy to manage and secure
- Having a fixed list of trusted operating systems can help enforce overall network security by allowing only known OS types and versions to access the networks
- Most endpoints use some sort of bootloader and firmware to secure and load the OS

Encryption, Disk Security, and DLP

- Full disk encryption (FDE): a software-based solution where the disk is encrypted by the operating system. On boot time, the UEFI loads the decrypting information from the OS. The cryptographic keys are usually stored in a trusted platform module (TPM) and protected by a password or other authentication method. After the keys are accessed, the disk can be decrypted, and the OS can be loaded normally. Because the entire disk is encrypted, if it is stolen, no useful information can be retrieved except by attempting to brute force the drive encryption, which is very costly.
- Self-encrypting drive (SED): a hard drive with a built-in module that automatically handles the encryption and decryption of the contents of the hard drive using instructions from the firmware and OS. using an SED drive pushes the cryptographic effort onto the built-in module in the hard drive, rather than the device CPU and software.
- Data Loss Prevention (DLP): can detect if someone is trying to copy sensitive information from a device or send it over the network, can block or log the transaction for security, prevents or limits the use of attachable drives like USB flash drives or external hard drives to prevent the copying

of large amounts of data, can also be network based where devices inspect network traffic to alert administrators to keywords or other sensitive information being transmitted over networks.

Endpoint Maintenance

- Updating OSs, firmware, and vulnerable software programs and applications is a simple and effective way to reduce overall risk
- Having a fully patched and updated system can help slow down and restrict the compromising of systems
- Further infiltration may be hindered because no other tools in an attacker's toolkit will be effective
- Having a comprehensive backup solution can greatly assist in recovering from cyberattacks or accidents
- Having backup equipment that you can configure easily to replace damaged, stolen, or compromised devices should be a part of a comprehensive disaster recovery plan

Endpoint Protection Platform (EPP): developed from the need of administrators to ensure servers and desktops are patched and have the appropriate antivirus software installed, viewed as a defensive measure against malicious attacks. Modern EPP platforms can:

- Verify versions of software and firmware
- Scan the local system for viruses and malware
- Enforce data loss prevention and other company-defined security policies
- Help administrators maintain uniform software updates across the enterprise
- Allow basic monitoring and visibility into systems

Endpoint Detection and Response (EDR): a more protective security solution that constantly scans a device to detect indicators of compromise (IOCs). If an EDR program detects a suspicious action, program, connection, or behavior, it can block the action and send an alert. This can help identify and stop threats like ransomware and zero-day attacks that may not have an established signature that would be detected by traditional anti-malware systems.

EDR usually leverages artificial intelligence and large comprehensive databases of known attacks to predict and recognize suspicious files and programs. In addition to detection and immediate response, EDR can trigger alerts to other connected endpoints and allow other endpoints to immediately block the suspicious program or file, even before it can be opened, or executed, providing an immediate response against zero-day and other previously unidentified attacks. EDR systems can also have tools to help security investigators gather data on new threats, and quarantine systems that are suspected of compromise.

Both EPP and EDR solutions usually provide monitoring resources to allow security administrators to have top-down visibility on the health of their endpoints, and allow a quick response in case of potential attacks or outages. These are usually a key

component in monitoring by a security operations center. In addition, many EDT solutions allow an immediate response by automating the process to either lock down devices, or execute operations in response to a threat detected by other parts of the network.

Securing Unknown and BYOD Endpoints

Many companies now allow employees to use BYOD computers and phones. Because these devices are usually not well-known and not managed by the company, allowing them to connect directly to a corporate network is a large risk.

- Having monitoring software and detection in place to identify and isolate unknown devices is a critical step in properly onboarding and securing these devices.
- Force all new and unknown devices onto an isolated network until they can be secured and registered. A physically separate network, VLAN, or a dedicated Wi-Fi access point can be used to accomplish this. Once a device is registered, usually by hostname, serial number, MAC address, or static IP address, appropriate monitoring software can be installed, and the device is moved to a production environment, as a known endpoint.
- Enforce the principle of least privilege. If these devices need access only to a specific internet or internal server, isolate them on a unique network, and allow only that specific connection through firewalls and routers. That way, if the device does not meet network compliance because they are not running an appropriate endpoint security solution, it has as limited access to other resources as possible.

Once all known devices are registered, many network security devices can be configured, such as wireless access points, switches, routers, firewalls, and other connectivity points, to lock down and not allow unauthorised devices to connect through the network. Disabling devices that are not monitored:

- Forces users with unknown devices to register
- Prevents attackers from attempting to insert their own devices onto the network remotely, or by attempting to physically plug in a device locally.

Module 9: Secure Data and Applications

Protecting sensitive data includes security and privacy safeguards for:

- Data at rest: refers to stored data
- Data in use: refers to data that is being used, created, or edited
- Data in transit: refers to data that is being moved or shared

to ensure the:

- Confidentiality: refers to keeping data private. In the digital world, encryption is a method that is commonly used to achieve confidentiality

- Integrity: ensures that data is authentic, accurate, reliable, and free from tampering. Integrity can be verified using hashing and protected using digital signatures
- Availability: data must be available to those who need it. People need to be able to access the information they require when they need it in a timely matter
- Non-repudiation: prevents someone from denying that they took an action that they have, in fact, completed. A private key is used for identification purposes. If there is any doubt that someone other than the owner has access to this key, then non-repudiation is lost.

of data assets. Therefore, data protection is a combination of data privacy and data security.

Data Security: maintaining the integrity of digital and physical assets, including the tactics and techniques used to protect against unauthorised access and exploitation of sensitive data, ensuring the integrity of data throughout the entire data lifecycle, which includes protecting personal data from unauthorized third-party access and malicious attacks, properly authorizing use and access, which is achieved by ensuring that only those with proper authority have access to sensitive data, data sovereignty, meaning that data is subject to the laws and governance structures of the nation where it is collected, and data privacy.

The Importance of Data Protection

Beyond the financial risk to organizations, companies risk the loss of intellectual property and proprietary data, the loss of public trust and loss of customer trust as a result of a data breach. Legal risks can also be involved, including the potential investigations performed by the information commissioner's office, and even the police. In the case of the payment card industry, data breaches that include a lack of compliance with data protection standards can result in lawsuits, loss of contracts, and loss of business.

Types of Data

There are numerous data types that must be secured:

- Controlled Unclassified Information (CUI): government created or owned
- Personally Identified Information (PII): can be private, public, or restricted information, includes addresses or biometric data
- Protected Health Information (PHI): healthcare related
- Payment Card Industry (PCI): administers and is responsible for electronic payments
- Sensitive Institutional Data: legal, regulatory, administrative, and contractual requirements
- IT Security Information: sensitive data within a protected network
- Export Control Records: export restrictions
- Student Education Records: maintained by educational agency or institution

Data Risks

- Accidental data exposure
 - APIs allow two applications to interact in the cloud without any user action.
 - The use of insecure external-facing APIs can provide unauthorized access to sensitive data data
- Unintentional data sharing
- Through phishing attacks where the attacker sends a fraudulent message to trick the receiver into sharing information
- Infection by malicious software
 - Malware: software designed to intentionally disrupt a device to gain unauthorized access to private information
 - Ransomware: software that can lock a system and threaten to publish a victim's personal data or permanently block the system unless a ransom is paid
 - Doxware: ransomware that threatens to release sensitive, embarrassing, or incriminating personal data or images to the public, if the user does not pay the ransom
 - Leakware: programs that slip into systems largely unnoticed and collect privileged information and personal data that is supposed to be protected. Once an attacker believes that they have collected enough sensitive data to pose a threat, they then can demand a payment in exchange for not releasing any of the data they have collected
- Internal threats
 - Employee inadvertently moving restricted or sensitive data to the cloud, or providing authorised access to sensitive data
 - Legitimate credentials being stolen, and the corresponding account being compromised
 - A malicious employee intentionally stealing confidential company data for fraud, sabotage, espionage, revenge, or extortion

The Data Lifecycle

During the data lifecycle, data is moving between multiple states, meaning it is constantly moving between rest, transit, and use. Risks are present throughout the data lifecycle, which consists of five main stages:

1. Creation
2. Storage
3. Usage
4. Archiving
5. Destruction

Other best practices for a company's data lifecycle management include:

- Following naming conventions
- Backing up data according to policy
- Archiving according to policy

- Deleting data according to guidelines
- Following data management policy

Data Protection Tactics and Techniques

- Training: helps everybody understand the importance of data protection. It ensures that the data usage policies are clearly understood and applied. Through training, employees become aware of the importance of creating strong passwords, regularly installing updates and patches, using multifactor authentication whenever possible, and controlling access to their sensitive data
- Data Obfuscation: also known as masking, can minimize the value of sensitive data to unauthorized intruders. It also differentiates information availability according to authorization levels.
- Encryption: another way to enhance the confidentiality of data. It can also be used to provide data integrity.
- Data Resiliency: important for availability and business continuity. Regular backups or high storage availability allow an organization's data to always be available and accessible, even if that organization experiences unexpected business corruption or disruptions, such as cyberattacks.
- Destruction: must be performed with the correct procedure, like erasure, which overwrites the existing data with meaningless, pseudo-random patterns to destroy it completely.
- Data Loss Prevention: for automatic data protection, data loss prevention (DLP) allows the detection and prevention of data breaches, exfiltration, or unwanted destruction of sensitive data.

Best Practices

- Data Loss Prevention (DLP) reduces risks while improving regulatory compliance. DLP helps organizations to:
 - Identify sensitive information across multiple on-premises and cloud-based systems
 - Prevent accidental sharing of data
 - Audit and monitor data movements
 - Educate users on how to stay compliant

For complete data protection while in use, in transit, or at rest, you can implement DLP in these different parts of a network:

- The endpoint, usually as a software-based client on a laptop or a workstation
- The network level, usually on the perimeter to detect data in transit
- The storage place, meaning on the data-center servers to inspect data at rest
- In the cloud, as software as a service (SaaS) that protects data being stored in cloud services

Data Privacy: refers to the proper handling of personal data and other sensitive data types. Data privacy also includes the public's expectation of privacy, and the right to have control over their own personal data. Organizations have an obligation to balance the processing of personal data with ensuring that individual privacy preferences are respected and protected. Overall data privacy focuses mainly on the process organizations use to collect, process, share, archive, and delete sensitive data, policies for acceptable levels of risk, as well as compliance with data protection regulations and privacy laws.

The Importance of Data Privacy

- Data is extremely valuable. It is an asset that when it is collected, it must be protected.
- Data privacy laws exist to ensure individuals have control over their data.
- Organizations must be transparent and effectively communicate their data management strategy, including what data they collect, why they collect it, who can access the data they collect, and how they will store it, manage it, delete it, and share it.
- Governments across the world recognize the importance of an individual's right to privacy. The protection of this right is reflected in many data privacy and protection laws.
- The collection of private, personal data has become easier with advancements in technology. It is vital that companies protect this data.
- Non-compliance has many consequences, such as fines, lawsuits, reputational damage, and loss of customer loyalty.

Privacy risk is the likelihood of experiencing problems resulting from data processing.

Data breaches are extremely costly both to a company's reputation, as well as its finances. In the event of a data breach, personally identifiable customer data has a high cost of about \$150 per record.

Roles of Organizations in Data Privacy

- Proprietary research, HR resources, and financial information must be protected from exposure, in order to maintain operations.
- To protect sensitive data, organizations must:
 - Identify sensitive data assets and classify the impact severity of such assets
 - Identify authorized roles, users, and policies, for the retention of private data
 - Collect and report on data asset compromise
 - Develop timely response procedures that detail how to notify stakeholders of data spillage or breaches and how to effectively recover from a compromise
 - Implement cryptographic measures for data obfuscation

- All information assets should be assigned a classification level, such as restricted (highly sensitive data and its use should be limited to a need-to-know basis), confidential (team-wide data and its use should be contained within the business), internal (company-wide data and should be protected with limited controls), or public (public information and can be openly shared on your website, discussed in public, and with anyone). This is based on the appropriate audience for the information, because the sensitivity level guides the selection of protective measures to secure the information, and data handling controls differ depending on the sensitivity level of the data.
- All policies pertaining to the classification and handling of data within each data classification level must be followed.

Data privacy laws and regulations are in place to ensure that individuals have control over their data.

Employees have an obligation to:

- Understand the data privacy regulations followed by their organizations
- Adhere to all policies and procedures related to data privacy

Governments also recognize the importance of an individual's right to privacy.

The protection of this right has been reflected in many data privacy and protection laws, including:

- GDPR: General Data Protection Regulation, protects individual rights and freedoms related to the protection of personal data
- ISO 27701: International Organization for Standardization 27701 Compliance, an international standard for privacy and information management. It includes the requirements against which a company's information security management system is audited
- NIST SP 800-53: National Institute of Standards and Technology, provides a catalog of security and privacy controls to protect against privacy risks
- SOC 2: System and Organization Controls, a compliance requirement for all Software as a Service (SaaS) companies that use cloud-based storage of customer data
- PIPEDA: The Personal Information and Electronic Documents Act, the Canadian national data privacy law for the private sector
- CCPA: California Consumer Privacy Act, a law that aims to increase the privacy rights of Californians in relation to the personal data collected by companies. It allows individuals to determine how a business can use and manage their personal information
- HIPAA: Health Insurance Portability and Accountability Act, a health industry regulation that requires healthcare organization who have access to protected health information to ensure the protection of sensitive patient health information
- PCI DSS: Payment Card Industry Data Security Standard, a global information security standard for organizations that store, process, or transmit payment or cardholder data

Secure Email Gateway (SEG): a technology solution designed to protect organizations from email-based threats to ensure the security and privacy of their email communications. It serves as a barrier between an organization's email infrastructure and the external email network, i.e., the internet. The features of SEG include:

- Content filters are used to control and manage the types of content that can be accessed or shared on a network. They are often used in web filtering, email filtering, and data loss prevention (DLP) to enforce content-related policies.
- DLP strives to prevent the unauthorized or accidental leakage of sensitive and confidential information from an organization.
- Content filters target a broader range of content, including not only spam, but also other types of content, such as inappropriate or sensitive data. Technologies used for content filtering can vary widely and may include keyword matching, regular expressions, deep packet inspections, and context-aware analysis.
- Like content filters, spam filters aim to manage email and eliminate harmful content, but they serve different purposes and target different types of content. Spam filters aim to reduce the amount of spam that reaches a user's inbox. They focus on identifying emails based on characteristics commonly associated with spam, such as suspicious sender addresses, excessive use of certain key words, known spam patterns, IP addresses with poor reputations. Spam filters are highly automated and use algorithms and heuristics to make decisions about whether an email is spam. They often maintain databases of known spammers and patterns to enhance their accuracy. Common technologies used for spam filtering include bayesian filters, deny lists, allow lists, and machine learning algorithms.
- SEG supports various methods to authenticate senders' identities and validate email sources to prevent email spoofing and impersonation.
- Malware filtering scans email attachments and links for malware to prevent potentially harmful content from reaching the recipient's inbox.
- SEG can encrypt email to protect the content from unauthorized access during transmission.

Sender Policy Framework (SPF): works at the level of the receiving email server, when an email is sent, the recipient's email server checks the SPF record of the sender's domain to verify whether the sending server's IP address is authorized to send emails on behalf of that domain. If the sending server's IP address is not listed in the SPF record, the recipient's server may flag the email as suspicious, reject it, or take other actions based on the recipient's email server's configuration. This process helps prevent email spoofing, and sender address forgery by verifying the authenticity of the sending server. SPF works alongside other email authentication technologies, like DomainKeys Identified Mail (DKIM) [an email authentication and anti-phishing technology that helps verify the authenticity of email messages and the legitimacy of the senders. DKIM uses digital signatures to allow email recipients to check that an email was indeed sent by the claimed domain and that it has not been altered in transit], and

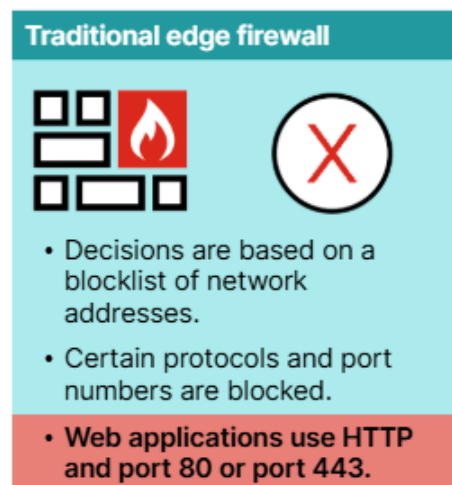
Domain-based Message Authentication, Reporting and Conformance (DMARC) [an email authentication protocol and framework used to enhance the security of email communication by allowing email senders to specify their email authentication policies and instruct email receivers on how to handle messages that fail authentication. DMARC builds on two other email authentication methods: Sender Policy Framework (SPF), and DomainKeys Identified Mail (DKIM)], to provide comprehensive email security.

Web Application Firewalls (WAF): an appliance or software that monitors HTTP/HTTPS traffic and can block malicious traffic to and from a web application.

WAFs target content from specific web applications at the application level, while edge firewalls form secure gateways between the local area network (LAN) and outside servers at the network level. By inspecting HTTP traffic, a WAF can stop attacks that target web application security flaws, such as SQL injection, cross-site scripting (XSS), file inclusion, and security misconfigurations.

Origin of Application Firewalls

The ancestor of the WAF is the application firewall that was developed in the 1990s. Although largely a network-based firewall, it could target some applications or protocols, such as file transfer protocol (FTP) and remote shell (RSH), which is a command line computer program. The debut of the World Wide Web in 1991, was the “big bang” of the internet universe, which has been expanding at an accelerated pace ever since. The accessibility and openness of the internet permitted anyone to search and explore, but it also permitted bad actors to use it for their own sordid purposes. As more people and organizations became victims of espionage, theft, and other crimes, developing a defense against HTTP-based cyberattacks became a top priority. Because all web applications used HTTP and either port 80 or port 443, WAF could not rely on traditional edge firewall methods, which based decisions on a blocklist of network addresses and blocked specific protocols and port numbers.



Evolution of WAF Development

The soaring popularity of the internet soon led to an increase in the number and complexity of web applications, which made the signature-based approach to WAFs obsolete. As well, the number of false positives-alerts of attacks that were, in fact, legitimate connections grew to proportions that were beyond the capacity of IT security teams. The next generation of WAFs were more intelligent, the firewalls included an element of learning. WAFs could study application behavior and use what they learned to create a baseline. Then, they would use that baseline to evaluate attempts to access applications and determine if those attempts were normal or irregular, and therefore, suspect.

The next generation also introduced session monitoring and heuristics, which enabled the firewall to detect variants of known signatures. This was a step forward; however, the IT security teams that were overseeing application learning and defense efforts could not keep up with the rapid mutations of existing methods or increasing number of new exploits. Moreover, there was no defense against zero-day attacks, which exploit an unknown weakness in the code of an application.

The next logical evolution in WAF development was machine learning (ML). unencumbered by human supervision, behaviour analysis could now be done at machine speed, and could adapt to the ever-changing attributes of a threat. Other security features that were added to firewalls included the following:

- Distributed denial of service (DDoS) defense
- IP reputation
- Antivirus
- Data loss prevention (DLP)

WAFs could monitor HTTP traffic and stop any action that violated acceptable behavior. They could identify a user, correlate the user's attempted actions with their permissions, and stop any action that went beyond the scope of their role. WAFs could also share information and collaborate with other security devices in the network, such as other firewalls and sandboxes. This ability allowed WAFs to be part of a collective defense, rather than working independently. Sandboxing capabilities meant that suspicious material could be tested safely, in isolation from the network. Zero-day attacks could be exposed and quarantined in these sandbox environments, and their signatures could be shared with other devices in the network. In addition, any resulting discoveries could be uploaded to a threat intelligence center on the internet, where they could be communicated to other networks.

What is Content Filtering?

A process to screen or restrict access to objectionable emails, webpages, executables, and other suspicious items. It is a common security measure that is often built into internet firewalls and blocks content that contains harmful, illegal, or inappropriate information.

Types of Content Filters

Content filters are used in different ways to block access to different types of materials. Some content filters are:

- **Search Engine Filters:** rate web content according to its text and images. Text and images hold a specific weight, which is measured against a classification set. The weights vary based on whether the classification level is set to off, moderate, or strict. Machine learning helps define the weights to avoid possible false positives. Depending on the resulting value and the size of the document, the content can then be classified as safe, moderate, inappropriate, or rejected from a strict point of view. The search engine result will then display contents if they meet the level of classification set.
- **Email Filters:** check the header of incoming mails against real-time blackhole lists (RBLs are directories that contain lists of domain names, email servers, or IP addresses that are known to help, host, produce, or forward spam). The raw data of the body is scanned for inappropriate content, providing a spam confidence level that is similar to search engine weights. Email content filters also check attachments, identify keywords or potential unauthorized types of files, like executables, and complete the email content filtering. This enables users to block, quarantine, or reject malicious emails, including phishing, while accepting appropriate incoming emails.
- **DNS-Based Content Filters:** check the website during the resolution of the domain through DNS servers using blocklists. If the website is not allowed, the browser is redirected to a replacement message announcing that the page is blocked. Alternatively, a company can define an allowlist, including all company approved websites. DNS-based content filtering would then block all other websites.
- **Web Filters:** similar to DNS-based content filters, with an additional function that categorises websites. All websites and their contents are rated through machine learning, so that the access to a specific URL (uniform resource locator, provides a path to access a web resource) is allowed or blocked according to its category and the user's profile.

Benefits of Content Filters

- Allow organizations to block access to sites known to carry malware, protecting their data and users from malicious activity.
- Identify phishing or an exploit kit (contain code that enables a malicious actor to attack web browser vulnerabilities through extensions and plugins), blocking the access before it triggers a malicious download. This is important while cyber criminals increasingly develop new, more sophisticated ways to illegally access networks and steal data.
- Limiting user's access to only specific work-related internet can increase the bandwidth efficiency and enable faster connections for all employees.
- Organizations can use web filtering on web sites like social media and online shopping to increase staff productivity.

What is Application Hardening?

The security process of secure configuration and maintenance of apps to protect the corresponding data. Hardening is a recommended security requirement that is defined by various cybersecurity regulations and standards. Hardening helps minimize vulnerabilities and reduces the attack surface, thereby protecting the integrity of the application and safeguarding sensitive data.

Techniques for Application Hardening

Organizations aim to ensure the security of their workplace by:

- Reinforcing the use of company-approved tools and applications and training employees on secure workplace behaviors
 - Web browser: company IT must recommend a stable web browser. Employees are responsible for installing the approved web browser.
 - Cookies: users must clear all cookies, allow only required cookies, and configure cookies in the advanced security option
 - Add-ons: software modules added to a web browser to provide enhanced functionalities, like language support through direct translation. Users should only install official add-ons that are company approved
 - Pop-up blocker: pop-ups may be malware. Employees must turn on pop-up blockers and create an allow list
 - Active content: employees need to treat active content, like ActiveX controls (small programs that applications use to perform specific functions, such as displaying a calendar or playing a video), and java applets (small applications that capture mouse input, or control buttons or check boxes), with caution.

At a company level, a recommended proxy can also help to further protect against attackers. The proxy can filter restricted sites and increase bandwidth usage through caching and content filtering. You can implement the previously mentioned browsing policies through a configuration file that is applied to all users at a company. Applications and extensions must have the option for automatic updates and patch maintenance to continuously fix vulnerabilities and security flaws. You can apply the configuration file through a patch management system, or through an individual user as a recommendation for application hardening.

Individual user behavior plays a role in application hardening.

- The first behavior recommendation is to use an updated antivirus software to scan and block malicious code, like worms, Trojan horses, or spyware.
- Users can use an application allowlist that includes supported and recommended third-party applications. These lists may also include user account controls to prevent unauthorized access.
- Individuals should also eliminate or disable obsolete or unused applications to avoid backdoor openings for cyberattacks.
- Training users in security awareness is the most valuable hardening technique because each user becomes a human firewall. Training helps

users to create secure and strong passwords, recognize and understand social engineering attacks and apply appropriate action.

Benefits of Application Hardening

- Helps companies to provide a high level of security and confidence at the same time
- Improves application performance because it lowers the risk of attackers slowing them down, or even worse, blocking them.
- While implementing application hardening is costly and takes a lot of effort, the return on investment is greater.
- Provides a safer environment, inhibiting the efforts of attackers, and allowing easier security compliance and audits.

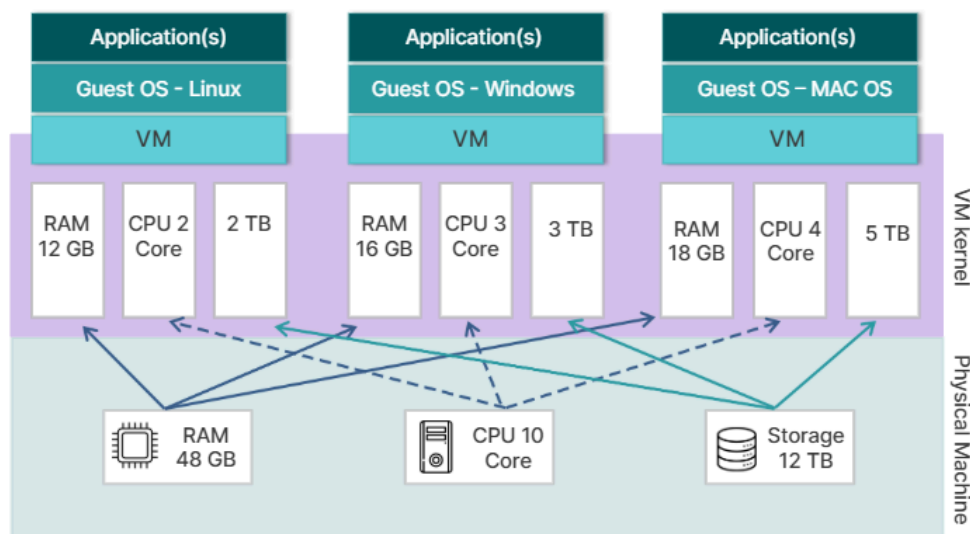
Module 10: Cloud Security and Virtualization

What is Virtualization?

The creation of a virtual version of something, such as an operating system (OS), a server, a storage device, or network resources.

How does Virtualization Work?

Virtualization uses software that emulates hardware functionality to create a virtual system. Virtualization software partitions hardware resources, such as processing memory and networking, onto a host machine. The host machine then allocates these resources so that multiple emulated machines can run on a single hardware platform. IT organizations can use virtualization to operate multiple operating systems, more than one virtual system, and various applications all on a single server.



Why Use Virtualization?

The benefits of virtualization include:

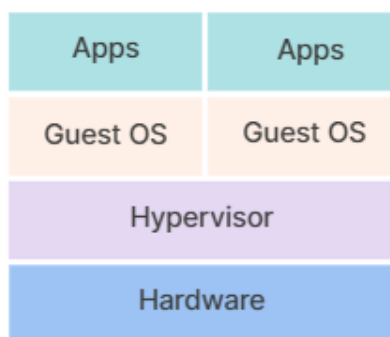
- Greater efficiencies and economies of scale: virtualization supports the efficient use of computing resources such as CPU, memory, and storage.
- Cost and energy savings: virtualized networks have no need for excessive hardware and have lower energy costs than non-virtualized environments.
- Virtualized production and test environments: virtualization can be used in production, development, and test environments, to virtualize specific types of services, such as database services, or servers, such as application servers.
- Improved disaster recovery mechanisms
- Quick and easy management: supports the quick and easy management of production environments, as well as the isolation of development and test environments.

What is a Hypervisor?

Also called a virtual machine monitor (VMM), a hypervisor is a type of computer software that enables the deployment and management of virtual machines. The hypervisor is responsible for partitioning hardware and system resources from the host system and managing the allocation of those resources for use by the VMs running on that system.

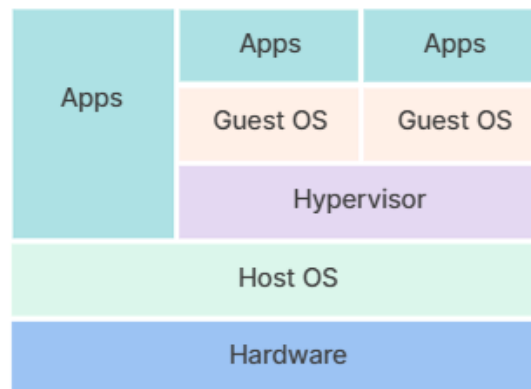
Types of Hypervisors

- Type 1 Hypervisor: also known as bare metal hypervisors, or native hypervisors. They run directly on the physical hardware of a computer, interacting directly with its CPU, memory, and physical storage. They take on the role of the OS and perform tasks involved with virtualization, such as resource partitioning and management. They can partition and manage the resource of the bare metal server, making it possible to implement multiple VMs to run on the server hardware. They are commonly used in data centers on high-performance hardware that is designed to run many VMs. They run on dedicated hardware, and they require a management console. Type 1 hypervisor vendors and products include Oracle VM Server for Sparc, ESXi, Hyper-V, Kernel-based VM (KVM), and others.



- Type 2 Hypervisor: also known as a hosted hypervisor. It acts as a VM manager on the host system. It is installed as a software application on

the system and runs over the existing OS on the host. A type 2 hypervisor runs on conventional operating systems, such as Windows, macOS, or Linux. It supports guest VMs by coordinating calls for host resources, such as CPU, memory, disk, network, and other resources, through the OS of the physical host. Unlike type 1 hypervisors, type 2 hypervisors don't have to run on dedicated hardware. This makes it easy for an end user to run a VM on a PC by installing the hypervisor software to coordinate the use of resources. Type 2 hypervisor vendors and products include VMware Fusion, Oracle Virtual Box, Oracle VM for x86, Solaris Zones, Parallels Desktop, VMware Workstation Pro, and others.



What is the Cloud?

The cloud refers to software and services offered by companies that specialize in making their data center resources available over the internet, rather than installing them on your computer or your physical network. One of the most commonly used cloud services is internet data storage. Once uploaded, data that is stored in the cloud can be accessed from anywhere using any device with an internet connection. Companies that specialize in the cloud usually offer a wide variety of IT services, including:

- Data storage
- Computing power
- Whole networks

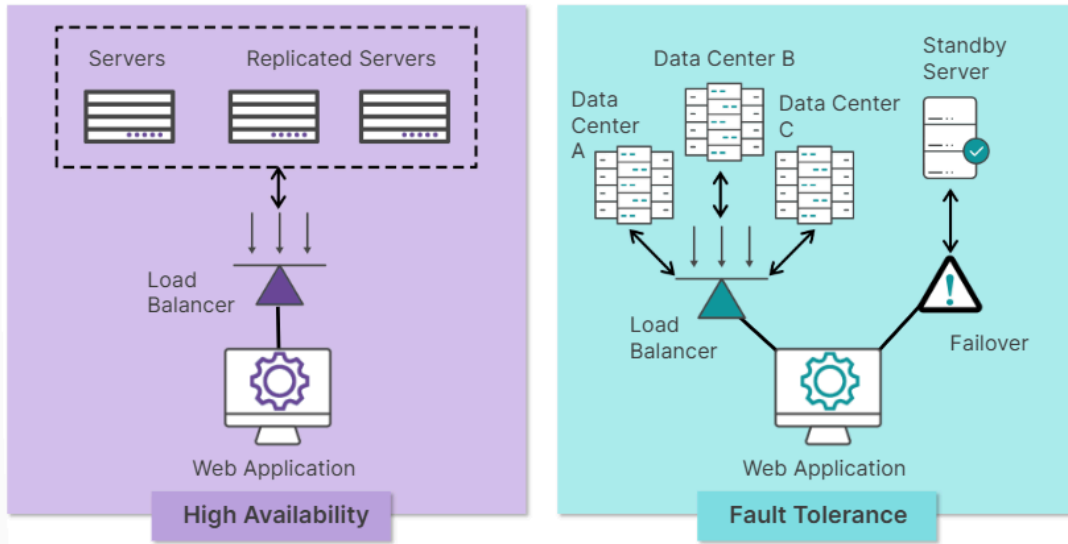
This enables businesses to potentially outsource parts of even all of their IT services.

Benefits of Cloud Services

A significant benefit of cloud services, compared to on-premises solutions, is that services provided in the cloud are easily accessible by everyone, because a working internet connection is all that is required to access those resources.

Why Use Cloud Computing?

Most cloud providers also offer the option to configure high availability (HA) and fault tolerance. This option keeps services up in the event of a failure, and enables disaster recovery in the event of data loss. The ability to configure HA and fault tolerance makes cloud services a reliable and safe solution for processing and storing large amounts of data.



Models of Services

There are three important service categories associated with cloud computing:

- Infrastructure-as-a-Service (IaaS)
- Platform-as-a-Service (PaaS)
- Software-as-a-Service (SaaS)

The main difference between these three service models is the degree to which customers must manage the underlying architecture of their products. Compared to an on-premises setup, where an organization manages all its hardware and software, a cloud solution relieves a customer of most of those responsibilities. The names of the three service models suggest the level of customer influence over their products.

	On Premises	IaaS	PaaS	SaaS	
Self-managed	Data	Data	Data	Data	Managed by Provider
	Application	Application	Application	Application	
	Databases	Databases	Databases	Databases	
	Operating System	Operating System	Operating System	Operating System	
	Virtualization	Virtualization	Virtualization	Virtualization	
	Server	Server	Server	Server	
	Storage	Storage	Storage	Storage	
	Network	Network	Network	Network	

Infrastructure-as-a-Service

When a customer implements IaaS, they are supplied with resources ranging from basic network, and processing power, to storage devices, and servers. The resources and networking are fully managed and maintained by the service provider. This means the customer can focus on building the environment using their own virtual machine, operating system, and applications. The advantage of this model over an on-premises solution is that the customer no longer has to worry about hardware; the service provider manages it. In addition, the customer does not have to spend money on new hardware. Instead, they pay to use only the resources offered by the provider. Examples of IaaS include a Linux VM in Amazon Web Services (AWS) or Microsoft Azure.

Platform-as-a-Service

In addition to hardware resources, a PaaS service model includes software such as the operating system (OS), databases, and application run-time environments, provided by the service provider. The addition of this software relieves the customer of even more management responsibility, because the service provider is responsible for the management and security of the environments they provide. The advantage of this model is that customers receive a reliable environment for testing, development, and hosting, without having to manage and maintain the underlying architecture. An example of PaaS is hosting a web application or web page.

Software-as-a-Service

SaaS is the perfect model for customers who need access to only specific applications and do not need a specific architecture or environment. This service model takes almost all of the responsibilities for the underlying architecture, platforms, and environments away from the customer. It leaves the customer responsible for only the software they want to use. Applications are usually accessed through a dashboard or an API, eliminating the need to install applications on the device currently in use. This model also allows swapping devices without worrying about migrating applications and data. An example of SaaS is access to Dropbox or OneDrive.

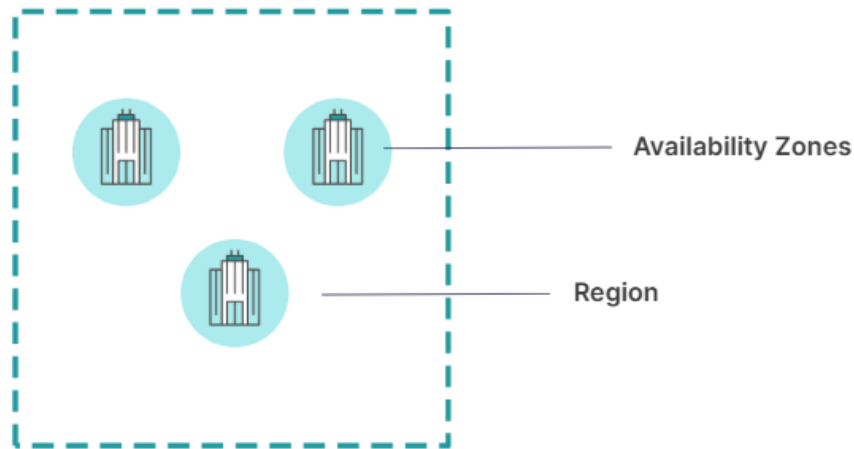
Who is Responsible for Security in the Cloud?

Security is a shared responsibility between the cloud provider and the customer using the cloud services. Cloud providers are responsible for the security of the cloud (storage, network, infrastructure, computer), while users are responsible for security within the cloud (data, applications, firewalls, encryption). However, most of the responsibility lies with the customer, because the majority of cloud security failures result from weaknesses or flaws in their applications.

Regions and Availability Zones

Usually, the cloud provider lets the customer choose the location of their services. This location is a geographical location referred to as a region. A region is a geographical area in which multiple isolated groups of data centers reside.

Within a region, availability zones are areas that house data centers. Multiple availability zones can exist within a region.



An availability zone usually consists of multiple data centers where the provided services run. Each group of data centers is provisioned with its own, usually redundant, power and networking. Each availability zone also has its own isolated power and network connectivity. Isolating groups of data centers into availability zones provides high availability (HA) and failover capability between the groups of data centers. The redundant design provides almost 24/7 uptime throughout the year, with minimal downtime.

Security for IaaS

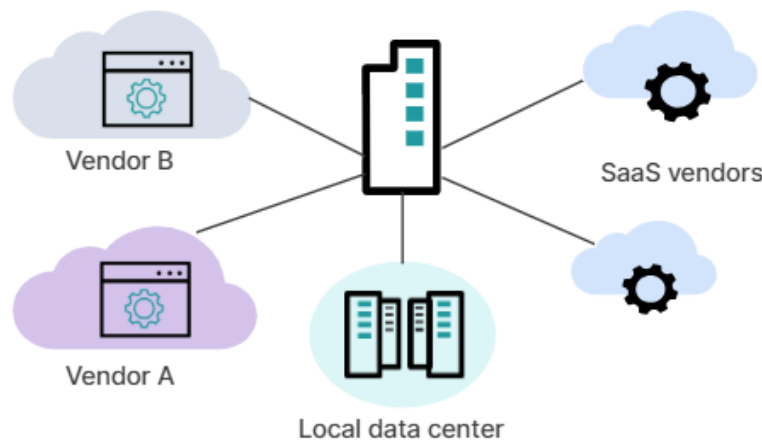
The cloud infrastructure provided by IaaS vendors is protected in various ways. From an availability point of view, the infrastructure is designed by the vendor to be highly available, and it follows that the infrastructure uptime is the responsibility of the vendor. From a security point of view, the vendor is responsible only for securing the infrastructure it provides. As a customer, when you install one or more virtualized applications in the vendor's cloud infrastructure, you are responsible for securing the access, network traffic and data applications.

Security Tools

Most vendors supply some form of security tools so that various parts of the customer's cloud application environment can be secured. However, these tools can pose a few problems:

- These tools tend to provide only a few basic security functions, and they are the same tools the vendors use to secure the underlying infrastructure. If an attacker were to bypass these tools at the infrastructure layer, they would likely be able to bypass them at the customer's application level as well.
- Many organizations operate in a hybrid world, where some of their applications remain hosted in their own data centers, some in Vendor-A IaaS cloud platform, some in Vendor-B cloud platform, and various others

with multiple SaaS vendors. This is called a multicloud environment, and it comes with a multicloud problem: multiple, independent, uncoordinated security solutions, a problem where complexity can scale geometrically with the number of cloud vendors involved.



Security Challenges

- Highly trained security staff are scarce
- It can be a burden to integrate and operate multiple non-integrated security environments simultaneously

Secure Virtualization: achieved using processes, procedures, and policies that ensure that the virtualized hardware infrastructure is secure and protected. Virtualization is the process of using a single physical hardware resource to create multiple virtual instances of working devices, such as computers. Virtual hardware may be located locally on a laptop, desktop, or servers in a data center, or it may be hosted by a third party in a cloud infrastructure and can be accessed only through web browsers and application programming interfaces (APIs).

There are two areas to consider when securing virtual resources: the physical security of the hardware (the host device that provides the resources to the hypervisor, can be a laptop, desktop, or servers), and the hypervisor (installed on a host device allows it to run one or more VMs by managing the distribution of the physical resources of that device). Because a virtual server can contain thousands of virtual computers, physically securing the hardware and maintaining a proper environment is critical. The loss or compromise of a single server can have severe consequences. The hypervisor software that runs on the physical server has direct access to all of the VMs that it is running. Securing the hypervisor and protecting its integrity and administrator accounts is critical to ensuring the security of all the VMs running on the hypervisor.

Through its improving availability, scalability, and elasticity, virtualization enables organizations to reduce infrastructure costs, but it also introduces additional challenges related to security, especially in relation to device uptime, data storage, and machine security.

Securing Virtual Environments

To secure VMs, you start with practices that are similar to the ones you use to secure traditional devices, including:

- Patching the OS and the applications regularly
- Using access management with strong password policies
- Installing firewalls virtually in the environment in-line with the protected VMs
- Implementing cloud-network segmentation to reduce the attack surface
- Limiting the connectivity between the VM and the host to segment them and avoid potential virus propagation through activities such as file sharing
- Removing unnecessary pieces of virtual hardware to reduce the attack surface
- Avoiding virtualization sprawl (when the number of VMs on a network reaches a point where administrators can no longer manage them effectively, resulting in some VMs not being properly secured or patched and therefore vulnerable) by implementing sound VM management planning and oversight such as allowing only specific administrations to deploy a standard list of validated VM images
- Restricting physical and administrative access to the hypervisor

Threats to Virtualization

Due to its nature, virtualization brings the following specific threats:

- An attacker can run a code on a VM that can allow them to break out and interact directly with the hypervisor. The operator can then gain access to the host operating system and therefore all the other VMs running on that host. This threat is called VM escape, and you can help prevent it by securing and patching the hypervisor and all virtualized operating systems, along with using strong access controls and passwords, and allowing the installation of only verified and trusted applications.
- Due to its elasticity, virtualization can create and remove large amounts of data dynamically. If this data is not correctly erased, the residual representation of digital data is called data remanence, which can be stolen by an attacker. To prevent data remanence, you must implement an appropriate secure data destruction process, including overwriting (writing over the existing data is a simple method that is still used as a first step because, increasingly, storage systems are designed to prevent data loss, meaning that data rewriting will not erase all the information), degaussing (rearranging the magnetic field on a hard drive to destroy or randomize the data. This makes the data irrecoverable and destroys the hard drive), crypto-erasing (on a storage device with encryption enabled, crypto-erasing removes the existing key and replaces it with a new one. All data that was encrypted using the previous key is rendered unrecoverable, but the device can still be used.), and shredding (an industrial machine is used to mechanically shred and destroy the drive leaving no possibility of reassembling the data).

- It is important to identify how a hosted virtualization platform handles sensitive data. To help control data security, store sensitive information on a separate, secured data with proper data protections, where VMs can access it.
- When VMs have weaknesses and security vulnerabilities, an attacker can exploit them for privilege escalation attacks. In this type of attack, the attackers grant themselves access to data they are not supposed to have, bypassing the proper authorization channel. Least privilege enforcement can prevent this type of attack.
- For availability and potential disaster recovery, virtualization allows VMs to move from one server or hypervisor to another. An attacker can potentially intercept this live VM migration, and, acting as a man in the middle, steal data, or alter the VMs during the migration. Encrypting the VMs and securing the data channels used in the migration can prevent this type of attack.

Common Cloud Threats

The biggest threat to public cloud and virtual environments is perceived to be errors in configuration, setup, and deployment. This is because virtual and cloud-based environments can be very complicated with multiple types of security layouts, network design, and infrastructure. Navigating and ensuring that all stages of a cloud-based environment are secure is an enormous task with very real impact if done incorrectly. Some of the common security risks for cloud environments include:

- Authentication and authorization: ensure modern authentication methods protect sensitive data and virtual machines. Also ensure that the cloud environment enforces the secure authorization of only valid users and devices using the principle of least privilege.
- VM creep: use frequent auditing of cloud-based virtual machines and data to reduce your fingerprint in the cloud and minimize your attack surface. Ensure that only resources that need to exist and be accessed, especially publicly, are allowed.
- Misconfigured storage: cloud-based storage is managed in units with their own unique sets of rules, authentication, and access control lists. Robustly securing and configuring these containers, disks, buckets, and blobs, is critical to prevent data loss, and excessive resource usage.
- Data loss: in addition to securely configuring storage, using data loss prevention platforms, and maintaining logging and other security tools, consider how cloud management companies handle data storage, rights, and ownership.
- Connectivity: always use secure network protocols like HTTPS, and SSH, when connecting to and maintaining cloud services and devices. Encrypt and secure data being transferred between cloud applications and storage using secure protocols.
- Improper logging and monitoring: for security purposes, always have access to security logs for your cloud environment. Cloud service companies may have very different methods of keeping and saving logs.

Being able to centralize this data collection into a SIEM device or other log collection point can help in maintaining security and aid in quickly responding to threats that affect the cloud environment.

- Rights and data ownership: data ownership in the cloud is an extremely complex issue. Data ownership depends on the country of the company that wants to use cloud services, the country where the cloud service provider is incorporated, and service level agreements (SLA) signed by the company and the hosting service. Having a clear picture of who owns the data hosted in the cloud is critical to prevent misunderstandings and potential data loss due to ownership conflicts and local laws.

Authentication and Authorization

One of the greatest concerns of cloud-based solutions is enforcing proper identification and authorization of users and devices to resources. Because connections to cloud services come from both local and public resources, it is critical to properly identify and restrict access to cloud-based data and resources. Because the potential attack surface of cloud-based services is so large, proper authorization of all potential connections and access is key to maintaining cloud security. It is important to secure authentication and authorization for users, management connections through HTTPS and API, and data connections to and from cloud services, to ensure only necessary connections are allowed.

Using a comprehensive authentication suite like OAuth and SAML, can be critical to enforcing security policies. These token based authentication systems allow connections from users and devices to connect to a wide variety of services. This is especially helpful when accessing cloud resources across multiple platforms because both OAuth and SAML support interoperability between various companies, services, and security devices. They can also simplify administration that supports an authentication database used for both local and cloud-based accounts and services.

Data Storage and Security

One of the most at-risk resources in the cloud is data. Personal information, credit cards, and intellectual property are all sometimes stored and accessed by cloud services. These types of resources usually have their own unique set of authentication rules and policies either enforced by cloud service provider local policies, identity and access management (IAM) systems, or storage access control lists (ACLs). Restricting access to cloud storage so that only authorised devices and users can access only the data they need is critical. Centralized authentication services and using the principle of least privilege for data access can help simplify this process.

Having a cloud-based data loss or leakage prevention (DLP) system in place to help monitor data connections between cloud-based services can help detect and prevent large-scale data leaks. Attackers have been very successful in exfiltrating data over time from cloud-based storage. Having a DLP device in the cloud to help detect suspicious data transfers can help prevent this.

An often overlooked way to help reduce storage demands and reduce the attack surface is to properly audit and remove any virtual machines, storage, and other cloud services that increase over time and that are not properly removed or deleted after use. Trimming unused or outdated cloud services reduces the number of resources used in the cloud, prevents old, undeleted systems from being potential security threats, and prevents initial attack points for malicious actors. Many of these types of data monitoring are rolled into cloud native protection, or CNP, or cloud native application protection, or CNAP platforms. They combine services like DLP, auditing, and risk assessment on one device.

API and CORS Policies

Because of the rise of application programming interfaces, or APIs, to deploy, configure, and maintain cloud services, you should take extra care to secure API connections using encryption to prevent sensitive information like passwords and encryption keys from becoming compromised. It is also critically important to secure API keys because attackers can use API interfaces to modify cloud interfaces and allow otherwise unauthorized access, or delete used cloud resources.

In addition to securing API and other management interfaces, it is crucial to verify that cross-site policies and permissions are restricted to only necessary connections because of the open and cross-site dependency of many cloud-based services. It is very common to use cross-origin resource sharing (CORS) to allow sharing of resources between websites. A cloud-based website can allow a user to access and load graphics and other information from a different cloud storage device using a CORS permission. While this greatly helps in the sharing of cloud-based resources, you must take care to ensure this mechanism is not exploited by attackers to execute cross-site scripting (XSS) attacks by tricking browsers or websites into accessing data and passing it along to other sites because of incorrectly or broadly set CORS permissions.

Improper Logging and Monitoring

Because of the frequently distributed nature of cloud-based services, especially those that may use multiple vendors and have data stored in different locations, it is sometimes difficult to have a comprehensive view of what is going on in a cloud environment. Log files can be kept locally in the cloud, forwarded to a cloud provider logging solution, or ignored. Collecting and collating this information as centrally as possible is useful in helping companies to maintain SLA targets and quickly detecting and preventing data breaches and other malicious activity.

Along with having a robust logging system in place to record activity in the cloud, real-time monitoring of the health of associated cloud systems, storage, and connections can be invaluable. This allows quicker response time to possible downtime events and potential attacks. You can perform logging and monitoring aggregation using devices hosted in the cloud close to the deployed cloud services, locally hosted devices that allow data to be sent from the cloud resources, or a combination of both. It is also possible to have logging and monitoring information gathered by a cloud solutions

provider, and then proxied to the security device of your choice to allow easier collection, and analysis across multiple platforms.

Hosting Network Security Devices

Traditional network devices, such as cloud native firewalls (CNFs) (a network firewall hosted in the cloud to protect hosted cloud services or to act as a central cloud gateway for local company branches), web application firewalls (WAFs) (a firewall that protects web servers and applications), and email gateways (an email server that can scan, store, and relay email messages to local mail servers), can all be hosted in a variety of cloud environments to allow immediate security for sensitive applications and data. These web optimized devices can also provide more traditional network services to cloud-based applications and servers, like high availability (HA), packet shaping, and latency optimization.

In addition to being near cloud services, having security devices in the cloud can simplify security for companies that have many small branch offices. Centralizing services in the cloud can reduce costs by eliminating expensive dedicated links to a main office that may not be centrally located or may be expensive to access through traditional network links.

A cloud-based firewall can replace a locally hosted firewall and centralize network security in one place, allowing only local network traffic to be routed to each branch location through a secure virtual private network (VPN). Additionally, large cloud-based data centers and SaaS environments may use cloud firewalls to provide an additional layer of protection against potential attackers.

Secure email gateways can be hosted in the cloud, allowing all incoming email to be scanned and verified in the cloud, before being forwarded to a local email server. Cloud-based WAFs sit in front of cloud-hosted web servers to provide load balancing, security, and scalability to large cloud-hosted web farms, in addition to targeted security, to help prevent common attacks against web servers, and to maximise availability and uptime.

Hosting Security Devices

In addition to hosting network security devices in the cloud, other security services like centralized authentication, virus scanning, and secure browsing, are also now available in cloud-hosted variants. These services grant users additional convenience and features that may have traditionally been available to only those users who are physically located at a main branch office.

Cloud-based authentication, or Authentication-as-a-Service, helps companies host and configure identity and access management (IAM), single sign-on (SSO), and two-factor authentication in a central location for both local, and cloud-based services. Authentication is usually some form of Lightweight Directory Access Protocol (LDAP), security assertion markup language (SAML), or open authorization standard (OAuth). This can simplify identity management and create a more centralized configuration of

user policies for both cloud and local services, if most of the used applications support the authentication method. Authentication proxies can be used to extend support for additional types of authentication methods.

A further refinement of authentication as a service is a cloud access security broker or CASB. This allows you to authenticate and control user access to cloud-based applications, regardless of where the users come from and how they authenticate. Instead of performing authentication for each individual cloud-based application, authentication is handled by the cloud-sensitive security broker, which authorizes users to access the defined applications.

A cloud browser, also known as a remote browser, or a remote browser isolation (RBI), is a web browser SaaS instance that runs in the cloud and behaves like a regular, locally installed web browser. The security benefit of using a remote browser is that all network connections and file access is controlled in a tightly secured remote sandbox. This limits the damage to files executed by the browser and makes it easier to defend the user from cross-site scripting (XSS) and other network attacks because the browser is not hosted on the user's local machine.

Cloud-based antivirus services and sandboxes accept files from local or cloud-based servers for scanning. Antivirus services inspect files for malicious code using both traditional lists as well as heuristic and AI-based services. Sandboxes create a virtual machine (VM) of a target operating system and execute the file in an isolated, secured environment. The execution, behavior, and usage of disk and memory resources can then be analyzed to determine if the file is safe.

Integrating Cloud-Hosted Security Services

One of the biggest advantages of leveraging the cloud for security is the ability to easily send data from many different endpoints to a central server in the cloud. A central cloud logging server can accept logging information from local hardware devices spread across the internet, as well as from cloud services applications and cloud security infrastructure. Having all this information sent and stored in a central location makes safeguarding, processing and reviewing data using devices like a security information and event management (SIEM) much simpler than having them located in many different local servers. Because scalability and reliability are the two biggest benefits of using cloud services, keeping reliable backups and uptime metrics is much simpler in a cloud environment.

Having security information and management centralized in the cloud also empowers security operation centers (SOCs). These centers rely on quick, reliable, and centralized data collection to properly monitor indicators of compromise (IOCs) and the general health of your network. SOCs are responsible for the escalation of and response to malicious activity. Having centralized control of network devices and logging through cloud-provided services and applications can greatly simplify the execution of these activities. An additional benefit of using centralized cloud security operations is the ability to leverage external company expertise using a

SOC-as-a-Service (SOCaaS). Cloud environments allow easy access to a dedicated security operations staff that performs the day-to-day monitoring of security events and are immediately available to respond to possible threats.

Consolidated Cloud Security Services

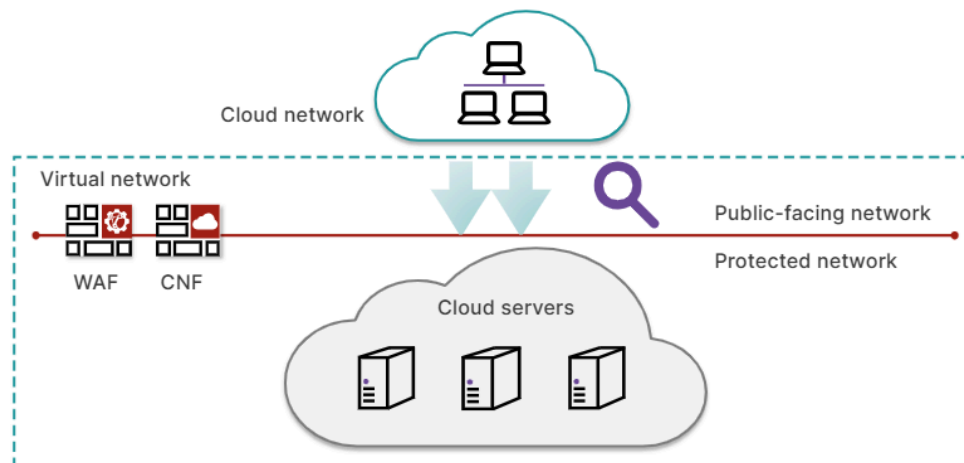
Many security companies now provide a service to help centralize and simplify cloud security concerns. This usually involves integrating software agents and accounts that allow security companies to examine and monitor cloud environments and perform security and penetration testing assessments to help identify risk factors. These services are referred to as cloud native protection, or CNP, or cloud native application protection, or CNAP. These services can vary widely, depending on the vendor, so it is important to verify that they support the environment that your cloud applications are deployed on, and that they provide the services you require.

CNP and other bundled cloud security services are also referred to as Security-as-a-Service (SECaaS). SECaaS allows companies to use a single vendor to provide multiple online security tools and devices, all integrated into one CNP platform. Services like disaster recovery, virus scanning, intrusion protection, and authentication can all be provided as a service through these online platforms, with additional features added as needed. There is a huge variety in the scale of services offered by these programs: from a simple web firewall-to fill in a temporary gap in security, to a complete security infrastructure hosted on the cloud-in which the only local security device in each office is a simple router or firewall that allows access to the secure cloud infrastructure.

Secure access service edge, or SASE, is a cloud architecture model that combines network and SECaaS functions and delivers them as a single cloud service. SASE aims to extend networking and security beyond simple connections between offices and cloud applications. SASE allows remote workers to take advantage of Firewall-as-a-Service, secure web gateway (SWG), zero-trust network access (ZTNA), and a medley of threat detection functions, regardless of their location. SASE combines secure networking from software defined WAN with a security service edge containing SECaaS products to validate and secure connections to hosted applications.

Securing Cloud Servers

Protecting cloud servers, such as email or web servers, can be straightforward. Many cloud environments allow the deployment of a web application firewall (WAF), and cloud-native firewall (CNF), directly into their virtual networks. This allows the administrator to partition the public facing cloud network and from the protected network containing the cloud servers. You can then perform traditional security procedures, such as policy rules, traffic inspection, and authentication at this virtual network perimeter by the cloud-native security devices. You can also perform enhanced logging and data monitoring at this boundary using devices like data loss prevention and intrusion detection systems to prevent unauthorized data access and loss.



In addition to firewalls, you can host data loss prevention scanners, antivirus engines, and sandboxes in the cloud next to these cloud servers to provide immediate security services instead of sending data across possible unsecured links. The other major benefit of cloud security services is that you can easily replicate additional cloud locations for cloud security services, to add another layer of security with minimal deployment and administrative costs.

Securing Cloud Authentication and Applications

Securing authentication and applications in the cloud is best done as close to the cloud services as possible. Introducing long connection times between authenticating servers and their applications can cause usability problems. Since sensitive data can pass between the user, application server, and application, controlling and securing these links is extremely important. Ensure that users authenticate over an encrypted link like SSL or using a VPN.

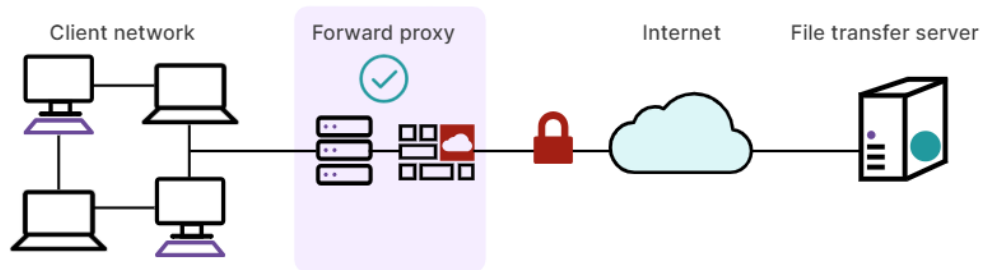
Cloud Service Connections

You should protect cloud-hosted authentication servers, such as Active Directory, or LDAP, using CNF and connections enforced using the principle of least privilege to ensure that only allowed applications can access authenticated users, and administrators are restricted to known devices and network links. Proxying connections and controlling access to these services, either through network controls, or authorization restrictions, is critical to ensure that your applications, and especially your sensitive services, such as authentication, are as protected as possible.

Forward Proxy

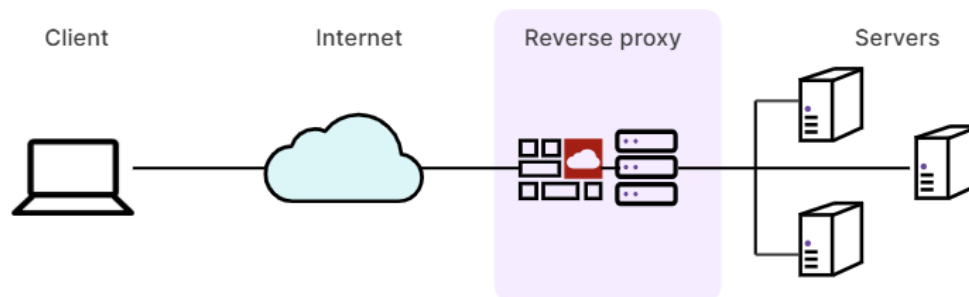
When connecting to cloud applications, it is important to secure and control access to the data and services. This control is either done on the client side or server side. Securing connections directly from clients is generally performed by a forward proxy, which is often a network firewall that accepts the connection and then brokers it forward to the destination server. The forward proxy can then authenticate and enforce all connections to applications from clients. Forward proxies ensure that no connection

from the client is ever allowed to directly connect to an application and allows for a very granular enforcement of your users' traffic. The disadvantage of forward proxies is that you must deploy one in front of each of your users, which can be difficult if your company has multiple branch offices and remote workers. Forward proxies also are of limited use when you want to secure your cloud applications from external, internet-based threats.



Reverse Proxy

A reverse proxy is positioned in front of the servers and applications to be protected. This enables the reverse proxy to verify and authenticate all incoming connections before passing the traffic to the target server. One of the advantages of using a reverse proxy is that it can load balance connections across multiple identical servers to allow greater scalability. Reverse proxies, such as a WAF, can also provide application-specific enforcement and protection tailored to each application. The disadvantages of a reverse proxy are that you must deploy them directly in front of the application to be effective, and you might find them difficult to deploy appropriately in a cloud environment that has applications in multiple locations and shifting data centers.



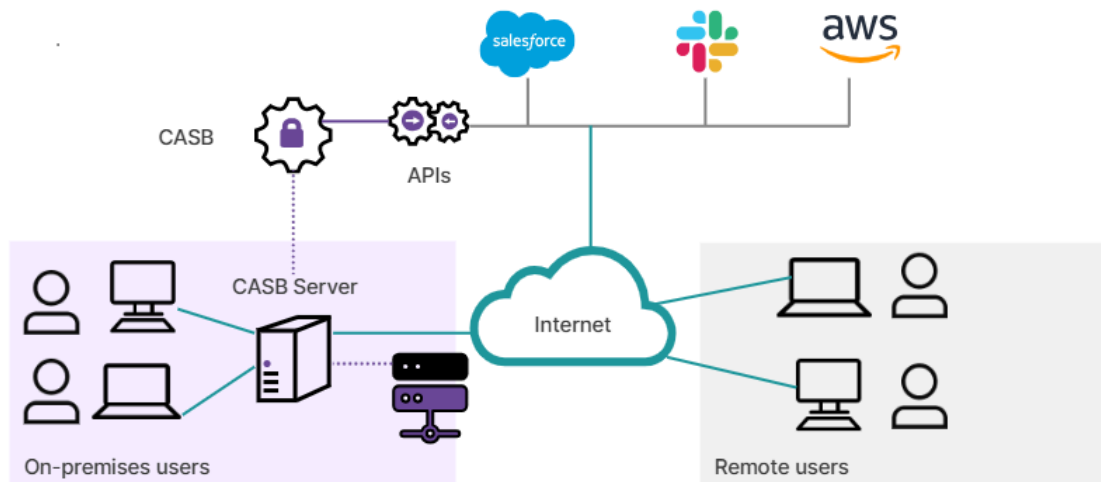
Application Cloud Interface

While you can use proxies to intercept traffic being sent to and from cloud applications, a third way of security cloud-based applications has emerged thanks to the expansions of the use of API. APIs are used to submit and receive information from an application. Common uses of API include configuring firewalls, Twitter bots, pulling information from weather and mapping sites, and online payments.

Cloud Access Security Broker (CASB)

CASB servers can use APIs to directly communicate with cloud application providers to configure and allow authorized users, and scan data stored by the application to ensure and prevent data loss. So instead of configuring a proxy in front of

every cloud application, the cloud applications are configured to work with the CASB server to enforce authentication and provide access so the CASB server can scan stored data. This can greatly simplify deployment because configuration must occur only on the cloud application and the CASB server. The main limitation of an API-based CASB deployment is that not all cloud-based applications have a compatible API to allow this interaction to occur. In such cases, you must use a proxy to secure the cloud application. Many CASB servers can also act as a proxy for cloud applications in addition to using APIs directly with the application to enforce security.



Additional APIs

There are two main types of API:

- Representation state transfer (REST): use REST for quick configuration and simple monitoring. REST uses a simple request-and-response model like the way a web page is retrieved from a website. Use a REST API to request information from the server or send basic configuration changes.
- Simple object access protocol (SOAP): uses an XML schema to package the request as an HTTP POST request. The server receives the full contents of the request and responds with another SOAP envelope containing the body of the response. Because SOAP packages the request and responses in the XML envelope, it tends to be slower than a REST API and is mostly used for legacy applications, or applications that require stateful sessions.

Securing APIs is critical, because they exchange sensitive information, such as usernames and passwords. You can secure APIs by encrypting the connections between them using HTTPS, VPNs between the client and server, or an API gateway. An API gateway is a WAF that can identify and scan API connections and enforce security. It does this by verifying the authentication used by the API session, and enforcing API schemas. An API schema is the set of commands and API calls that the API is expected to use. If a request deviates from the expected commands, the API gateway blocks it. For example, if the API call to change an IP address is not part of the

approved schema, the API gateway prevents that call from being used, even by a valid user session. This ensures that the API session uses only approved commands and prevents malicious actors from injecting commands into the API.